BAN CƠ YẾU CHÍNH PHỦ

HỌC VIỆN KỸ THUẬT MẬT MÃ



BÁO CÁO AN TOÀN MẠNG MÁY TÍNH

Nghiên cứu giải pháp Endpoint Detection and Response (EDR) và triển khai thử nghiệm trên nền tảng mã nguồn mở Wazuh

Khoa: Công nghệ thông tin

Mã nhóm: 2

Sinh viên thực hiện:
Phạm Thị Minh Ánh - AT200403
Hoàng Hải Dương - AT200415
Phạm Xuân Hồng - AT200422
Hà Thế Nam - AT200441

Khoa công nghệ thông tin – Học viện Kỹ thuật mật mã

Hà Nội - 2026

MỤC LỤC

Nội dung

MỤC LỤC ii
DANH MỤC HÌNH ẢNH ..... **Lỗi! Thẻ đánh dấu không được xác định.**
DANH MỤC BẢNG BIỂU ..... **Lỗi! Thẻ đánh dấu không được xác định.**
DANH MỤC TỪ VIẾT TẮT iv
LỜI MỞ ĐẦU 1
CHƯƠNG 1. TỔNG QUAN VỀ AN NINH ENDPOINT VÀ EDR 2
1.1. Bối cảnh tấn công mạng nhắm vào Endpoint 2
1.2. Hạn chế của Antivirus truyền thống 2
1.3. Khái niệm và nguyên lý cốt lõi của EDR 3
1.3.1. Khái niệm EDR 3
1.3.2. Lịch sử hình thành và các cột mốc phát triển của EDR 5
1.4. Vị trí của EDR trong hệ sinh thái an ninh mạng 7
1.4.1. Mối quan hệ giưac EDR và các giải pháp liên quan 7
1.4.2. Vai trò của của EDR trong kiến trúc phòng thủ nhiều lớp 9
1.5. Tổng kết chương 1 11
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ KIẾN TRÚC KỸ THUẬT CỦA EDR 12
2.1. Kiến trúc tổng thể hệ thống EDR 12
2.1.1. Mô hình phân tầng: Endpoint Agent và Central Backend Analytics Engine 12
2.1.2. Chu trình xử lý liên tục khép kín (Continuous Feedback Loop) 13
2.2. Cơ chế thu thập dữ liệu 14
2.2.1. Thành phần và nguồn dữ liệu thu thập 14
2.2.2. Kỹ thuật thu thập tại endpoint 15
2.2.3. Lọc, chuẩn hóa và truyền dữ liệu 16
2.3. Cơ chế phân tích và phát hiện đe dọa 17
2.3.1. Phân tích dữ liệu và xây dựng ngữ cảnh 18
2.3.2. Phát hiện dựa trên quy tắc và chỉ dấu xâm phạm 19
2.3.3. Phát hiện dựa trên chỉ số tấn công (IoA), phân tích hành vi và phát hiện bất thường 20
2.4. Cơ chế phản hồi và giảm thiểu sự cố 21
2.4.1. Đánh giá và lựa chọn phương án phản hồi 22

2.4.2. Các kỹ thuật ngăn chặn trực tiếp tại Endpoint 23
2.4.3. Phản hồi tự động kiểm soát cảnh báo sai 23
2.4.4. Điều tra sau phản hồi và khôi phục hệ thống 25
2.5. Ứng dụng MITRE ATT&CK trong EDR 25
2.5.1. Cấu trúc của MITRE ATT&CK và mô tả hành vi tấn công 25
2.5.2. Quy trình chuẩn hóa và xây dựng Rule phát hiện bám sát TTPs 26
2.6. Xu hướng EDR tích hợp AI & XDR 26
2.6.1. Ứng dụng Trí tuệ nhân tạo (AI) và Học máy trong EDR 26
2.6.2. Xu hướng tiến hóa từ EDR lên Nền tảng XDR 27
2.7. Tổng kết chương 2 27
CHƯƠNG 3. THỰC NGHIỆM TRIỂN KHAI GIẢI PHÁP EDR (WAZUH) 29
KẾT LUẬN 44
TÀI LIỆU THAM KHẢO 46
PHỤ LỤC 47

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh	Trắc nghĩa tiếng Việt
EDR	Endpoint Detection and Response	Phát hiện và phản ứng trên thiết bị đầu cuối
EPP	Endpoint Protection Platform	Nền tảng bảo vệ thiết bị đầu cuối
SIEM	Security Information and Event Management	Hệ thống quản lý thông tin và sự kiện an ninh mạng
NDR	Network Detection and Response	Hệ thống phát hiện và phản ứng trên lưu lượng mạng
XDR	Extended Detection and Response	Nền tảng phát hiện và phản ứng mở rộng
SOAR	Security Orchestration, Automation and Response	Nền tảng điều phối, tự động hóa và phản ứng an ninh
IoC	Indicators of Compromise	Chỉ dấu / Dấu hiệu xâm phạm
IoA	Indicators of Attack	Chỉ số / Dấu hiệu tấn công hành vi
MTTD	Mean Time To Detect	Thời gian trung bình để phát hiện sự cố
MTTR	Mean Time To Respond	Thời gian trung bình để phản ứng / xử lý sự cố
APT	Advanced Persistent Threat	Tấn công mạng có chủ đích và dai dẳng
SOC	Security Operations Center	Trung tâm điều hành / vận hành an toàn thông tin
DFIR	Digital Forensics and Incident Response	Điều tra số và ứng cứu sự cố an ninh mạng
FIM	File Integrity Monitoring	Giám sát tính toàn vẹn của tệp tin
SCA	Security Configuration Assessment	Đánh giá cấu hình an ninh hệ thống

LỜI MỞ ĐẦU

Trong bối cảnh chuyển đổi số diễn ra mạnh mẽ, số lượng và mức độ tinh vi của các cuộc tấn công mạng nhắm vào thiết bị đầu cuối như máy trạm, máy chủ ngày càng gia tăng. Endpoint không chỉ là điểm truy cập phổ biến nhất mà tin tặc lợi dụng để xâm nhập hệ thống, mà còn là nơi lưu trữ, xử lý phần lớn dữ liệu nhạy cảm của tổ chức. Các giải pháp bảo mật truyền thống như phần mềm diệt virus dựa trên chữ ký ngày càng tỏ ra kém hiệu quả trước các kỹ thuật tấn công hiện đại như tấn công không dùng mã độc, khai thác lỗ hổng zero-day, hay đặc biệt là hành vi lạm dụng các phần mềm hợp pháp như phần mềm điều khiển truy cập từ xa để thiết lập kênh điều khiển ẩn danh, né tránh các cơ chế phát hiện thông thường.

Trước thực trạng đó, giải pháp Endpoint Detection and Response ra đời như một bước tiến quan trọng, cho phép giám sát liên tục hành vi trên endpoint, thu thập và phân tích dữ liệu theo thời gian thực, từ đó phát hiện sớm các dấu hiệu bất thường, hỗ trợ điều tra và phản ứng nhanh trước sự cố an toàn thông tin. Tuy nhiên, các giải pháp EDR thương mại thường có chi phí triển khai và vận hành cao, gây khó khăn cho các tổ chức vừa và nhỏ hoặc các đơn vị nghiên cứu, đào tạo.

Wazuh là một nền tảng mã nguồn mở tích hợp các tính năng giám sát an ninh và khả năng phát hiện, phản ứng trên endpoint, được cộng đồng an toàn thông tin đánh giá cao nhờ tính linh hoạt, khả năng mở rộng và chi phí triển khai thấp. Việc nghiên cứu, triển khai thử nghiệm Wazuh nhằm phát hiện các kịch bản tấn công thực tế mang lại giá trị thực tiễn cao, giúp làm rõ khả năng ứng dụng của giải pháp mã nguồn mở trong công tác giám sát và bảo vệ hệ thống endpoint. Xuất phát từ những lý do trên, đề tài "Nghiên cứu giải pháp Endpoint Detection and Response và triển khai thử nghiệm trên nền tảng mã nguồn mở Wazuh" được lựa chọn thực hiện.

Nghiên cứu tổng quan về giải pháp EDR: khái niệm, kiến trúc, nguyên lý hoạt động và vai trò trong hệ thống phòng thủ an toàn thông tin nhiều lớp.

Nghiên cứu kiến trúc, cơ chế hoạt động và các thành phần chức năng của nền tảng mã nguồn mở Wazuh, làm rõ khả năng đáp ứng vai trò của một giải pháp EDR.

Xây dựng và triển khai thử nghiệm mô hình giám sát endpoint sử dụng Wazuh trong môi trường Lab.

Đề xuất quy tắc phát hiện (detection rule) và hướng cải tiến nhằm nâng cao hiệu quả giám sát, phát hiện đối với các kỹ thuật tấn công tương tự.

CHƯƠNG 1. TỔNG QUAN VỀ AN NINH ENDPOINT VÀ EDR

1.1. Bối cảnh tấn công mạng nhắm vào Endpoint

Trong những năm gần đây, endpoint gồm các máy trạm, máy chủ, thiết bị di động và các thiết bị IoT trong mạng doanh nghiệp đã trở thành mục tiêu ưu tiên hàng đầu của tin tặc. Sự dịch chuyển mô hình làm việc từ xa, việc sử dụng thiết bị cá nhân để truy cập tài nguyên công ty (BYOD) và xu hướng chuyển dịch lên nền tảng đám mây đã làm mở rộng đáng kể bề mặt tấn công (attack surface), khiến ranh giới mạng truyền thống dựa trên chu vi (perimeter-based) không còn đủ khả năng bảo vệ toàn diện.

Các báo cáo an ninh mạng thường niên của nhiều tổ chức uy tín liên tục chỉ ra rằng phần lớn các cuộc tấn công thành công đều bắt đầu từ endpoint: từ email lừa đảo (phishing) chứa mã độc, khai thác lỗ hổng phần mềm chưa được vá, cho đến việc lạm dụng các công cụ hệ thống hợp pháp (living-off-the-land) để né tránh phát hiện. Đặc biệt, sự bùng nổ của mã độc tống tiền (ransomware), các cuộc tấn công có chủ đích (Advanced Persistent Threat - APT) và các kỹ thuật tấn công không sử dụng tệp tin (fileless malware) đã cho thấy kẻ tấn công ngày càng tinh vi, có khả năng ẩn mình trong hệ thống trong thời gian dài trước khi bị phát hiện.

Một đặc điểm đáng chú ý của các cuộc tấn công hiện đại là chúng thường không dừng lại ở một hành vi đơn lẻ mà diễn ra theo chuỗi nhiều giai đoạn (kill chain): từ trinh sát, xâm nhập ban đầu, thiết lập chỗ đứng (persistence), leo thang đặc quyền, di chuyển ngang (lateral movement) cho đến khai thác hoặc phá hoại dữ liệu. Điều này đòi hỏi các giải pháp bảo vệ endpoint không chỉ dừng lại ở việc ngăn chặn tại thời điểm xâm nhập, mà còn phải có khả năng giám sát liên tục, ghi nhận hành vi và hỗ trợ điều tra xuyên suốt vòng đời tấn công.

1.2. Hạn chế của Antivirus truyền thống

Antivirus (AV) truyền thống hoạt động chủ yếu dựa trên cơ chế phát hiện theo chữ ký (signature-based detection): phần mềm so khớp mã băm (hash) hoặc các đoạn mã đặc trưng của tệp tin với cơ sở dữ liệu mã độc đã biết. Cách tiếp cận này từng phát huy hiệu quả trong giai đoạn mã độc còn ít biến thể và lây lan chậm, nhưng ngày càng bộc lộ nhiều hạn chế trước bối cảnh tấn công hiện đại.

Về khả năng phát hiện:

- Chỉ phát hiện được mã độc đã biết: AV truyền thống gần như bất lực trước các biến thể mới, mã độc zero-day hoặc mã độc được đóng gói/mã hóa (packer, obfuscation) để thay đổi chữ ký nhận diện.
- Thiếu khả năng phát hiện hành vi: nhiều kỹ thuật tấn công hiện đại như fileless malware, khai thác PowerShell, WMI hay các tiến trình hệ thống hợp pháp (living-off-

the-land binaries - LOLBins) không để lại tệp tin đáng ngờ nào để quét, khiến AV không thể phát hiện.

Về khả năng vận hành, điều tra và phản ứng:

- Thiếu khả năng nhìn nhận theo ngữ cảnh (visibility) và lịch sử: AV thường chỉ đưa ra cảnh báo "chặn/không chặn" tại một thời điểm, không lưu lại chuỗi hành vi trước và sau sự kiện, gây khó khăn cho việc điều tra nguyên nhân gốc rễ (root cause analysis) khi sự cố xảy ra.
- Khả năng phản ứng hạn chế: khi phát hiện mã độc, AV chủ yếu chỉ dừng lại ở việc cách ly hoặc xóa tệp tin, thiếu các công cụ hỗ trợ điều tra sâu, truy vết và phản ứng chủ động trên diện rộng.
- Thời gian phản hồi chậm với mối đe dọa mới: việc cập nhật cơ sở dữ liệu chữ ký cần thời gian, tạo ra khoảng trống bảo mật (gap) giữa lúc mã độc mới xuất hiện và lúc hệ thống được cập nhật để nhận diện.

Những hạn chế trên cho thấy antivirus truyền thống, dù vẫn là một lớp phòng thủ cơ bản cần thiết, không còn đủ để đối phó với các mối đe dọa có chủ đích và tinh vi trong bối cảnh hiện nay. Do đó, một thế hệ giải pháp bảo vệ endpoint mới đã ra đời để thay thế cho cách tiếp cận này, đó chính là EDR.

1.3. Khái niệm và nguyên lý cốt lõi của EDR

1.3.1. Khái niệm EDR

Khái niệm EDR (Endpoint Detection and Response) lần đầu tiên được định nghĩa bởi chuyên gia phân tích Anton Chuvakin thuộc hãng nghiên cứu công nghệ Gartner vào năm 2013. Theo định nghĩa chuẩn hóa của Gartner:

"Endpoint Detection and Response là một danh mục giải pháp bảo mật ghi nhận và lưu trữ các hành vi, sự kiện diễn ra trên các thiết bị đầu cuối; sử dụng các kỹ thuật phân tích dữ liệu chuyên sâu để phát hiện các hành vi đáng ngờ; cung cấp thông tin ngữ cảnh đầy đủ phục vụ điều tra sự cố và đưa ra các chỉ dẫn hoặc hành động khắc phục nhằm khôi phục trạng thái an toàn cho hệ thống."

Khác biệt căn bản và mang tính cách mạng nhất của EDR so với các giải pháp bảo mật trước đó nằm ở triết lý "Giả định đã bị xâm nhập" (Assume Breach):

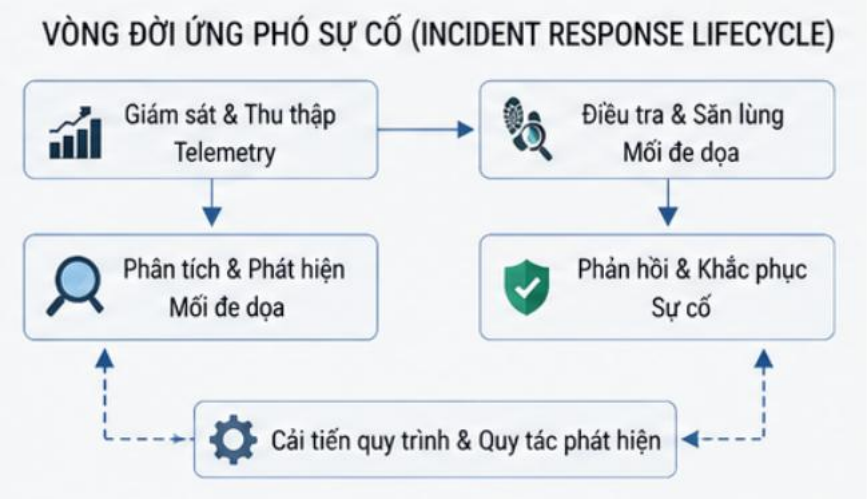


Trong tư duy bảo mật truyền thống, các tổ chức thường tập trung mọi nguồn lực vào việc ngăn chặn kẻ tấn công xâm nhập vào mạng nội bộ. Tuy nhiên, trước các kỹ thuật phi kỹ thuật (Social Engineering), lỗ hổng Zero-day trong phần mềm của bên thứ ba hoặc tấn công chuỗi cung ứng (Supply Chain Attacks), không có bất kỳ hệ thống phòng thủ nào có thể đảm bảo ngăn chặn được 100% các cuộc tấn công.

Triết lý Assume Breach của EDR thừa nhận rằng: Kẻ tấn công có thể đã có mặt bên trong hệ thống máy trạm. Do đó, mục tiêu của EDR không chỉ là cố gắng ngăn chặn ở bước đầu tiên, mà là:

- Tối thiểu hóa thời gian phát hiện (MTTD - Mean Time To Detect): Nhanh chóng nhận diện sự hiện diện của kẻ tấn công ngay khi chúng bắt đầu thực hiện các hành vi bất thường đầu tiên (như leo thang đặc quyền hoặc trinh sát nội bộ).
- Tối thiểu hóa thời gian phản ứng (MTTR - Mean Time To Respond): Kịp thời ngăn chặn, cô lập và vô hiệu hóa mối đe dọa trước khi kẻ tấn công kịp đạt được mục đích cuối cùng (như mã hóa tống tiền hoặc đánh cắp dữ liệu quan trọng).
- Giảm thiểu "Thời gian ẩn mình" (Dwell Time): Rút ngắn tối đa khoảng thời gian kẻ tấn công có thể âm thầm hoạt động trong hệ thống mà không bị phát hiện.
- Bốn trụ cột chức năng cốt lõi của giải pháp EDR

Một giải pháp EDR hoàn chỉnh được xây dựng dựa trên 4 khối chức năng liên hoàn:



- Thu thập dữ liệu liên tục (Continuous Telemetry Collection): Một phần mềm giám sát nhẹ (Agent/Sensor) được cài đặt trực tiếp trên các endpoint, hoạt động ở cấp độ sâu của hệ điều hành để liên tục ghi nhận các sự kiện hệ thống (tiến trình, dòng lệnh thực thi, tệp tin, mạng, Registry, phiên đăng nhập) và chuyển tiếp về máy chủ trung tâm để chuẩn hóa và lập chỉ mục.
- Phân tích và phát hiện dựa trên hành vi (Behavioral Detection & Correlation): Hệ thống sử dụng các công cụ giải mã (Decoders), tập luật phát hiện (Rule Engine), mô hình phân tích tương quan đa sự kiện và học máy để nhận diện các chuỗi hành vi tấn công (Indicators of Attack - IoA) và kỹ thuật TTPs, vượt qua giới hạn của các chữ ký tĩnh.
- Điều tra số và săn lùng mối đe dọa (Forensics & Threat Hunting): Cung cấp cho các chuyên gia phân tích SOC khả năng trực quan hóa toàn bộ chuỗi tấn công (Process Execution Trees), truy vấn dữ liệu lịch sử bằng các ngôn ngữ truy vấn mạnh mẽ, giúp xác định nguồn gốc xâm nhập và phạm vi lây lan của sự cố.
- Phản hồi và khắc phục sự cố (Containment & Remediation): Cung cấp các cơ chế phản ứng linh hoạt (thủ công hoặc tự động qua các kịch bản Active Response): cô lập máy trạm khỏi mạng nội bộ, tiêu diệt tiến trình độc hại, xóa các khóa khởi động ngầm (Persistence Registry Keys), hoặc khôi phục tệp tin bị mã hóa về trạng thái nguyên vẹn.

1.3.2. Lịch sử hình thành và các cột mốc phát triển của EDR

Quá trình tiến hóa của các giải pháp bảo vệ endpoint có thể được chia thành ba giai đoạn phát triển chính:

Giai đoạn 1 (2013 - 2016): Khởi nguyên và thế hệ EDR đầu tiên

- Bối cảnh: Thuật ngữ EDR ra đời nhằm đáp ứng nhu cầu cấp thiết của các đội ứng cứu sự cố chuyên nghiệp (Incident Response Teams) khi các giải pháp Antivirus truyền thống không thể giải thích được nguyên nhân các vụ xâm nhập quy mô lớn.

- Đặc điểm công nghệ: Thế hệ EDR đầu tiên chủ yếu đóng vai trò như một "Hộp đen ghi dữ liệu chuyến bay" (Flight Data Recorder) cho endpoint. Trọng tâm của các sản phẩm thời kỳ này (như Carbon Black, Mandiant MIR) là thu thập càng nhiều log sự kiện tiến trình càng tốt và lưu trữ lại để phục vụ việc tra cứu, tái dựng lại hiện trường sau khi sự cố an ninh đã xảy ra. Khả năng phát hiện tự động và ngăn chặn thời gian thực ở giai đoạn này còn tương đối sơ khai.

Giai đoạn 2 (2017 - 2020): Tích hợp Phân tích hành vi, Machine Learning và Chuẩn hóa MITRE ATT&CK

- Bối cảnh: Lượng dữ liệu Telemetry thu thập khổng lồ dẫn đến tình trạng quá tải thông tin cho các nhà phân tích bảo mật. Đồng thời, sự bùng nổ của Ransomware đòi hỏi hệ thống phải có khả năng ngăn chặn tự động tức thì thay vì chỉ điều tra sau sự cố.
- Đặc điểm công nghệ:
  - Các giải pháp EDR bắt đầu tích hợp các mô hình **Học máy (Machine Learning)** và thuật toán phát hiện bất thường (Anomaly Detection) để phân loại các hành vi độc hại chưa từng thấy.
  - MITRE ATT&CK Framework trở thành tiêu chuẩn công nghiệp chung để phân loại, ánh xạ và chuẩn hóa các quy tắc phát hiện (Detection Rules) theo từng kỹ thuật tấn công thực tế.
  - Xuất hiện các cơ chế phản hồi tự động thông qua kịch bản định sẵn (Playbooks / Active Response), cho phép tự động cô lập máy tính ngay khi phát hiện hành vi mã hóa dữ liệu hàng loạt. Các sản phẩm tiêu biểu: CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint.

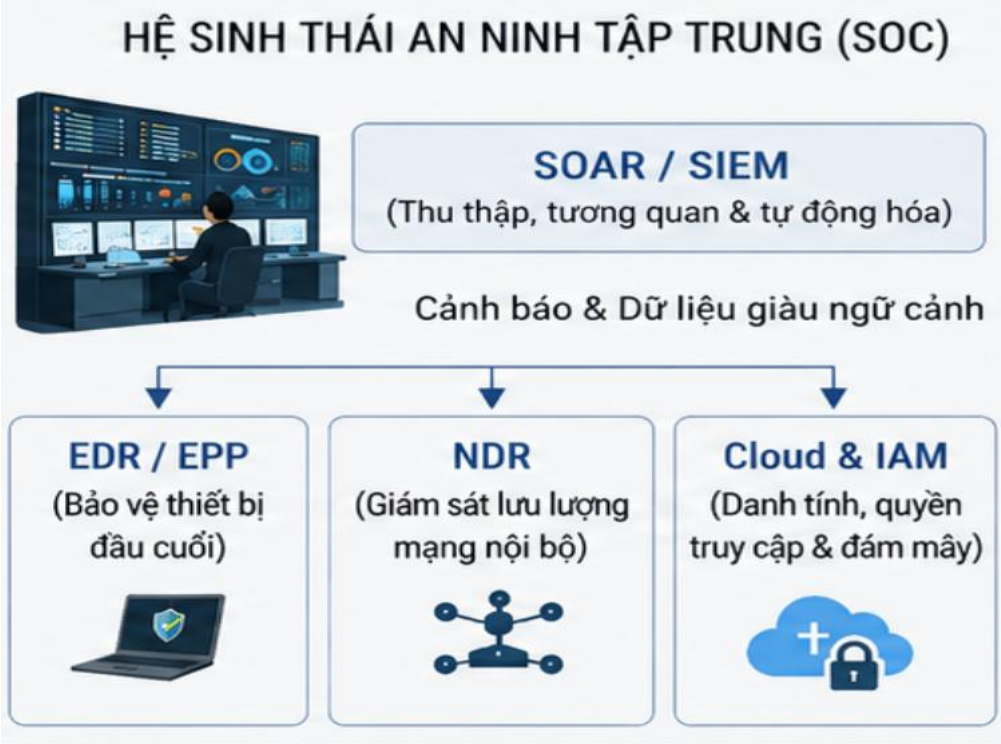
Giai đoạn 3 (2021 - nay): Hợp nhất EPP+EDR và Mở rộng sang XDR (Extended Detection and Response)

- Bối cảnh: Ranh giới giữa giải pháp phòng ngừa (EPP) và giải pháp phát hiện/phản hồi (EDR) dần bị xóa nhòa. Các doanh nghiệp yêu cầu một nền tảng duy nhất vừa có khả năng phòng thủ tĩnh mạnh mẽ, vừa có năng lực EDR chuyên sâu, đồng thời phải liên kết được dữ liệu ngoài phạm vi endpoint.
- Đặc điểm công nghệ:
  - Hợp nhất EPP + EDR: Các giải pháp hiện đại tích hợp sẵn cả tính năng ngăn ngừa mã độc truyền thống, kiểm soát thiết bị, vá lỗ hổng bảo mật và giám sát EDR trong một Agent duy nhất (Single Lightweight Agent).
  - Tiến hóa lên XDR: Mở rộng phạm vi tương quan dữ liệu từ Endpoint sang Lưu lượng mạng (NDR), Hệ thống định danh (Identity/Active Directory), Dịch vụ Email và Hạ tầng Đám mây (Cloud Security), giúp thiết lập bức tranh phòng thủ đa tầng đồng bộ.

- Sự phát triển mạnh mẽ của EDR mã nguồn mở: Các nền tảng mã nguồn mở như Wazuh (kết hợp năng lực SIEM và XDR) hay Osquery + FleetDM trưởng thành vượt bậc, cho phép các trường đại học, tổ chức nghiên cứu và doanh nghiệp vừa/nhỏ tự xây dựng hệ thống EDR tùy biến, linh hoạt và tối ưu chi phí.

1.4. Vị trí của EDR trong hệ sinh thái an ninh mạng

Trong một kiến trúc an ninh thông tin hiện đại, không có bất kỳ một giải pháp đơn lẻ nào có thể đảm bảo an toàn tuyệt đối. EDR không hoạt động độc lập và cô lập mà đóng vai trò là nguồn cung cấp ngữ cảnh chi tiết nhất và là công cụ can thiệp mạnh mẽ nhất trong hệ sinh thái an ninh mạng tổng thể của tổ chức.



1.4.1. Mối quan hệ giưac EDR và các giải pháp liên quan

Để định vị chính xác vai trò của EDR, cần xem xét mối quan hệ tương hỗ và sự khác biệt giữa EDR với các lớp giải pháp phổ biến khác:

EDR và Nền tảng bảo vệ Endpoint (Endpoint Protection Platform - EPP)

- Mối quan hệ: EPP là lớp phòng ngừa tuyến đầu (Pre-execution / Prevention), bao gồm Antivirus thế hệ mới (NGAV), tường lửa cá nhân, kiểm soát thiết bị ngoại vi (Device Control) và phòng chống khai thác lỗ hổng (Exploit Mitigation). EDR là lớp phòng thủ chuyên sâu phía sau (Post-execution / Detection & Response).
- Tính bổ trợ: Khi một mối đe dọa vượt qua lớp kiểm soát tĩnh của EPP (ví dụ: mã độc tống tiền mới chưa có chữ ký hoặc mã độc không dùng tệp), EDR sẽ theo dõi hành vi thực thi để phát hiện sự bất thường và ngăn chặn kịp thời. Xu hướng hiện nay là hợp nhất EPP và EDR trong một Agent duy nhất.

EDR và Hệ thống quản lý thông tin và sự kiện an ninh (SIEM)

- Mối quan hệ: SIEM đóng vai trò là "Bộ não tổng hợp" thu thập và phân tích log từ toàn bộ hạ tầng (tường lửa, máy chủ, thiết bị mạng, ứng dụng, cơ sở dữ liệu và thiết bị đầu cuối).
- Tính bổ trợ: SIEM thu thập log rất rộng nhưng thiếu độ sâu (thường chỉ có các dòng log sự kiện dạng văn bản rời rạc). EDR đóng vai trò là nguồn cấp dữ liệu giàu ngữ cảnh nhất (Rich Telemetry Provider) cho SIEM. Khi SIEM phát hiện một địa chỉ IP nội bộ bị nghi ngờ, phân tích viên sẽ dùng EDR để "nhìn thấu" vào bên trong máy tính đó: tiến trình nào đã tạo kết nối, tài khoản nào đã kích hoạt tiến trình, và cây tiến trình đó bắt nguồn từ đâu.

EDR và Hệ thống phát hiện và phản hồi trên mạng (Network Detection and Response - NDR)

- Mối quan hệ: NDR giám sát toàn bộ lưu lượng mạng (Network Traffic Analysis) ở các cổng mạng và thiết bị chuyển mạch để phát hiện các hành vi bất thường như quét cổng, trinh sát nội bộ hoặc truyền dữ liệu ra ngoài (Data Exfiltration).
- Tính bổ trợ:
  - Điểm mạnh của NDR: Giám sát được các thiết bị không thể cài đặt EDR Agent (như máy in, camera IP, thiết bị IoT, thiết bị y tế).
  - Điểm mạnh của EDR: Khi lưu lượng mạng bị mã hóa (HTTPS/TLS 1.3), NDR rất khó phân tích nội dung gói tin. Ngược lại, EDR hoạt động trực tiếp tại hệ điều hành của máy trạm nên có thể ghi nhận chính xác dữ liệu trước khi bị mã hóa và biết rõ tiến trình cụ thể nào đã tạo ra kết nối mạng đó. Hai giải pháp kết hợp tạo nên khả năng giám sát toàn diện từ Máy trạm đến Đường truyền mạng.

EDR và Nền tảng phát hiện và phản hồi mở rộng (Extended Detection and Response - XDR)

Mối quan hệ: XDR là bước tiến hóa tự nhiên của EDR. Thay vì chỉ giới hạn trong phạm vi thiết bị đầu cuối, XDR mở rộng khả năng thu thập và phân tích tương quan tự động dữ liệu từ nhiều tầng: Endpoint (EDR) + Network (NDR) + Cloud Workloads + Email Gateway + Identity (IAM/Active Directory) thành một hệ thống phát hiện và phản ứng thống nhất. Trong mô hình XDR, EDR chính là thành phần cốt lõi và quan trọng nhất.

EDR và Nền tảng điều phối, tự động hóa và phản hồi an ninh (SOAR)

- Mối quan hệ: SOAR tập trung vào việc tự động hóa các quy trình vận hành an ninh thông qua các kịch bản phản ứng chuẩn (Playbooks) và kết nối các công cụ bảo mật thông qua API.
- Tính bổ trợ: EDR cung cấp các cảnh báo chất lượng cao làm đầu vào kích hoạt các kịch bản của SOAR; đồng thời EDR cung cấp các hàm API (như cô lập mạng máy

trạm, xóa tệp, khóa tài khoản) để SOAR tự động thực thi các hành động ứng cứu khẩn cấp mà không cần con người thao tác thủ công.

1.4.2. Vai trò của của EDR trong kiến trúc phòng thủ nhiều lớp

a. Tuyến phòng thủ "Chặng cuối" trong mô hình Phòng thủ theo chiều sâu (Defense in Depth)

Mô hình Phòng thủ theo chiều sâu phân chia hệ thống bảo mật thành nhiều lớp đồng tâm:



Khi kẻ tấn công sử dụng các kỹ thuật tinh vi như gửi email lừa đảo chứa tệp đính kèm mã hóa mật khẩu, khai thác lỗ hổng Zero-day trên trình duyệt hoặc sử dụng kênh mạng riêng ảo (VPN) bằng tài khoản đánh cắp, toàn bộ các lớp phòng thủ chu vi và mạng ở phía ngoài sẽ bị vượt qua.

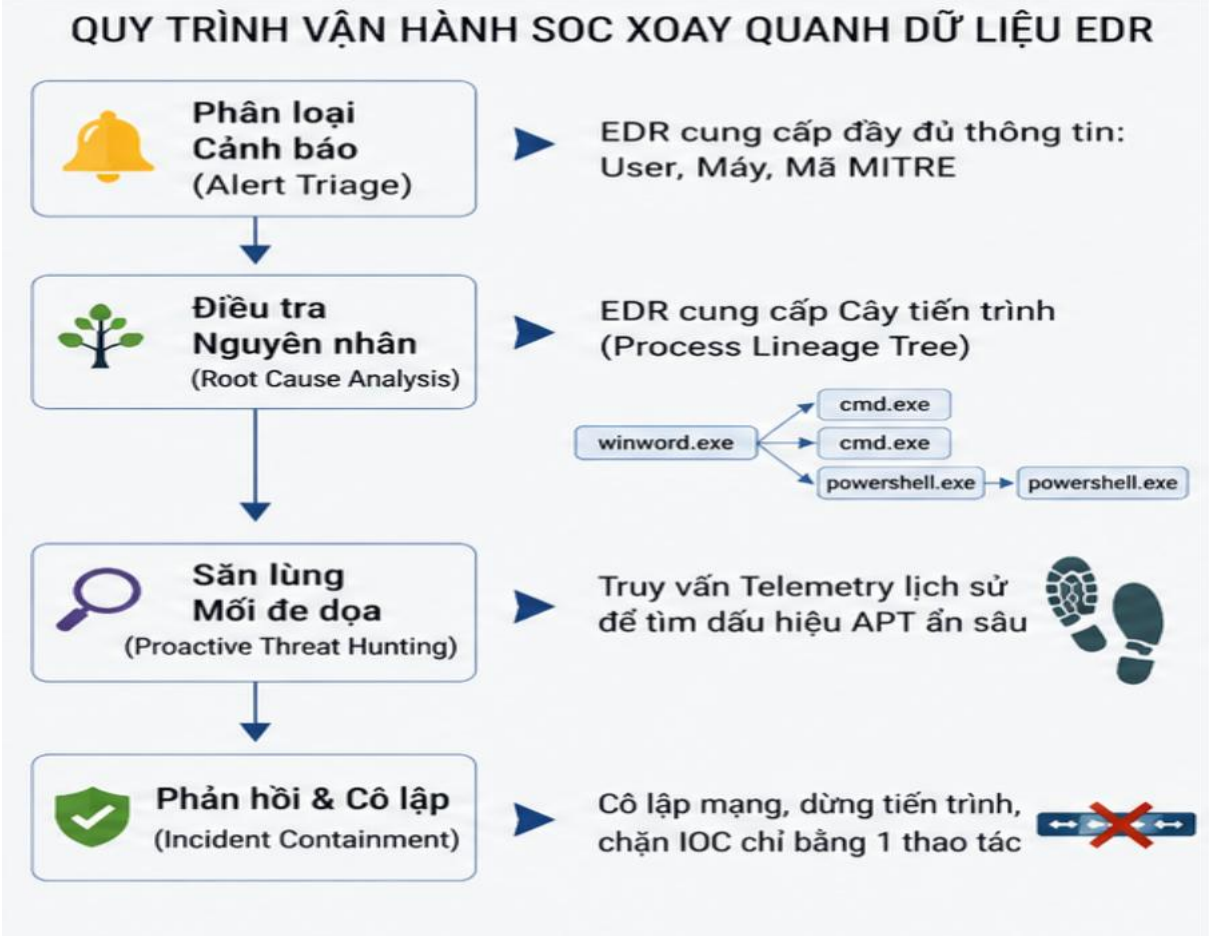
Lúc này, thiết bị đầu cuối chính là chiến trường cuối cùng. EDR giữ vai trò là tuyến phòng thủ mang tính quyết định nhờ các khả năng:

- Khả năng hiển thị độc lập với vị trí địa lý: Trong bối cảnh làm việc từ xa (Work from Anywhere), nhân viên mang máy tính ra khỏi mạng văn phòng để làm việc tại nhà hoặc quán café (không còn được bảo vệ bởi Firewall của công ty). EDR Agent vẫn liên tục giám sát và bảo vệ thiết bị dù nó kết nối vào bất kỳ mạng Internet công cộng nào.
- Ngăn chặn di chuyển ngang (Lateral Movement): Khi một máy trạm bị chiếm quyền điều khiển, kẻ tấn công sẽ tìm cách quét mạng và lây lan sang các máy trạm và máy chủ quan trọng khác. EDR phát hiện sớm các hành vi trinh sát nội bộ, trích xuất mã

băm mật khẩu từ bộ nhớ (như kỹ thuật LSASS Dumping) và chặn đứng chuỗi tấn công ngay tại nút mạng đầu tiên bị xâm phạm.

b. Trọng tâm vận hành trong Trung tâm điều hành an ninh (SOC)

Trong một trung tâm SOC hiện đại, EDR là công cụ cốt lõi phục vụ các hoạt động hàng ngày của chuyên viên phân tích an ninh (SOC Analysts) và chuyên gia ứng cứu sự cố (DFIR):



- Cải thiện 2 chỉ số vận hành sống còn (MTTD & MTTR):
  - MTTD (Thời gian trung bình để phát hiện): Giảm từ hàng tháng (đối với mô hình truyền thống) xuống còn vài phút nhờ các cơ chế phát hiện hành vi tự động và cảnh báo theo thời gian thực.
  - MTTR (Thời gian trung bình để phản ứng): Rút ngắn thời gian xử lý sự cố từ vài ngày xuống còn vài giây thông qua các tính năng cô lập mạng (Network Isolation) và hủy tiến trình từ xa bằng một cú nhấp chuột.
- Chuyển đổi từ "Phòng thủ bị động" sang "Săn lùng chủ động" (Threat Hunting): Thay vì ngồi chờ hệ thống phát ra cảnh báo, các kỹ sư bảo mật sử dụng kho dữ liệu Telemetry tập trung của EDR để chủ động chạy các câu truy vấn phức tạp nhằm tìm kiếm những hành vi bất thường chưa từng bị phát hiện trong quá khứ.

- Bảo toàn chứng cứ phục vụ giám định số (Digital Forensics): Khi một máy tính bị tấn công, kẻ phá hoại thường có xu hướng xóa dấu vết (xóa Windows Event Log, xóa tệp mã độc). EDR đã kịp thời truyền toàn bộ các bản ghi sự kiện chi tiết về máy chủ trung tâm từ trước đó, giúp bảo toàn tính toàn vẹn của chứng cứ số phục vụ công tác điều tra pháp y an ninh mạng.

1.5. Tổng kết chương 1

Chương 1 đã thiết lập bức tranh toàn cảnh về bối cảnh an ninh mạng trên thiết bị đầu cuối và làm rõ sự cần thiết mang tính tất yếu của giải pháp EDR:

- Bối cảnh đe dọa: Sự mở rộng của các mô hình làm việc kết hợp cùng với sự phát triển của các kỹ thuật tấn công tinh vi (APT, Ransomware, Fileless Malware, Living-off-the-Land) đã biến endpoint thành mục tiêu xâm nhập hàng đầu của tội phạm mạng.
- Hạn chế của Antivirus truyền thống: Phương pháp phát hiện dựa trên chữ ký tĩnh và phân tích tệp tĩnh đã hoàn toàn mất đi ưu thế trước các mã độc đa hình, mã độc trong bộ nhớ và các cuộc tấn công lạm dụng công cụ hệ thống hợp pháp.
- Bản chất của EDR: Được xây dựng trên triết lý "Giả định đã bị xâm nhập" (Assume Breach), EDR lấy việc giám sát liên tục, phân tích hành vi theo thời gian thực, điều tra ngữ cảnh sâu và phản ứng nhanh làm 4 trụ cột cốt lõi nhằm tối thiểu hóa thời gian phát hiện (MTTD) và thời gian phản ứng (MTTR).
- Vị trí chiến lược: EDR đóng vai trò là tuyến phòng thủ "chặng cuối" trong mô hình Phòng thủ theo chiều sâu (Defense in Depth) và là nguồn cung cấp dữ liệu ngữ cảnh phong phú nhất, phục vụ trực tiếp cho các quy trình vận hành và điều tra trong Trung tâm điều hành an ninh (SOC).

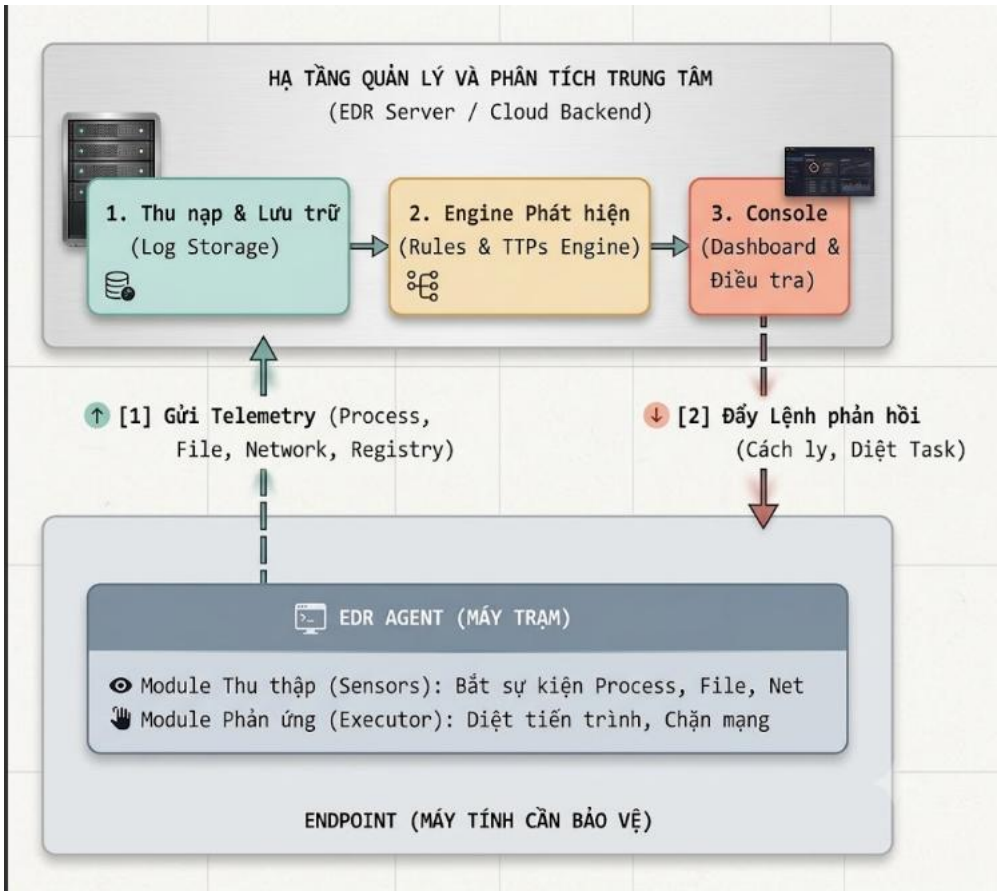
Những cơ sở lý luận trên là nền tảng quan trọng để tiếp tục đi sâu nghiên cứu kiến trúc kỹ thuật, cơ chế hoạt động chi tiết của EDR ở Chương 2, cũng như triển khai thực nghiệm mô hình phát hiện và phản ứng cụ thể trên nền tảng Wazuh ở Chương 3.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ KIẾN TRÚC KỸ THUẬT CỦA EDR

2.1. Kiến trúc tổng thể hệ thống EDR

2.1.1. Mô hình phân tầng: Endpoint Agent và Central Backend Analytics Engine

Một giải pháp EDR tiêu chuẩn được xây dựng trên mô hình phân tán bao gồm hai phân vùng kiến trúc chính: Thành phần phân tán tại máy trạm (Endpoint Agent/Sensor) và Hạ tầng phân tích trung tâm (Central Backend Analytics Engine) đặt tại máy chủ On-premises hoặc trên nền tảng Cloud.



Về mặt tổng thể, kiến trúc của một giải pháp EDR được tổ chức thành hai tầng chức năng rõ ràng với cơ chế tương tác hai chiều:

- Tầng Máy trạm (Endpoint Agent): Là một tiến trình/dịch vụ chạy ngầm trên thiết bị đầu cuối với hai nhiệm vụ cốt lõi:
  - Nhiệm vụ thu thập (Sensor): Lắng nghe và ghi nhận liên tục các hoạt động của hệ điều hành (tiến trình khởi chạy, kết nối mạng, thay đổi tệp tin và Registry) rồi đóng gói gửi về máy chủ.

- Nhiệm vụ thực thi (Executor): Tiếp nhận các chỉ thị từ máy chủ để thực hiện các hành động phản ứng tại chỗ (như hủy tiến trình độc hại, cách ly máy trạm khỏi mạng).

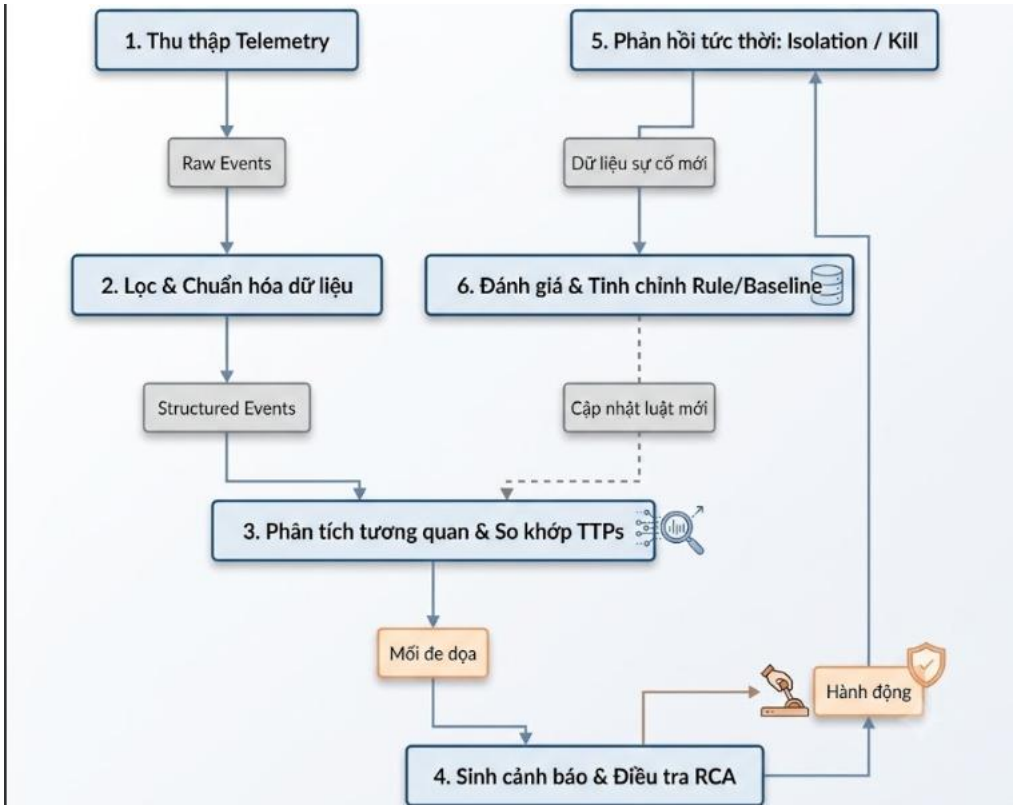
o Tầng Trung tâm (EDR Server / Backend): Đảm nhận vai trò xử lý tập trung:

- Khối thu nạp và lưu trữ: Tiếp nhận, chuẩn hóa và lưu trữ toàn bộ dữ liệu telemetry từ các Agent gửi về.
- Khối phân tích và phát hiện: So khớp dữ liệu với các tập luật (Rules), phân tích hành vi và ánh xạ theo khung MITRE ATT&CK để phát hiện tấn công.
- Giao diện quản trị (Dashboard): Cung cấp bức tranh toàn cảnh về an ninh, hiển thị cảnh báo cho phân tích viên và là nơi điều phối các chính sách phản hồi.

2.1.2. Chu trình xử lý liên tục khép kín (Continuous Feedback Loop)

Kiến trúc EDR vận hành như một chu trình xử lý khép kín gồm 6 giai đoạn liên hoàn, không chỉ xử lý sự cố tại thời điểm phát hiện mà còn liên tục học hỏi để tối ưu hóa khả năng phòng thủ trong tương lai:

Thu thập⟶Chuẩn hóa⟶Phân tích⟶Cảnh báo⟶Phản hồi⟶Tối ưu hóa



o Thu thập (Collect): Sensor tại máy trạm liên tục bắt giữ các sự kiện ở mức nhân và mức ứng dụng.

o Chuẩn hóa (Normalize): Dữ liệu thô từ nhiều hệ điều hành khác nhau được chuyển đổi về một cấu trúc dữ liệu thống nhất (như JSON, ECS, OCSF).

- Phân tích (Analyze & Correlate): So khớp dữ liệu chuẩn hóa với các chỉ số tấn công (IoA), mô hình hành vi bất thường và ánh xạ tới mã kỹ thuật MITRE ATT&CK.
- Cảnh báo và Điều tra (Alert & Investigate): Khi phát hiện hành vi nguy hiểm, hệ thống tạo cảnh báo có ngữ cảnh, tự động dựng cây tiến trình (Process Lineage) giúp phân tích viên xác định nguyên nhân gốc rễ (Root Cause Analysis - RCA).
- Phản hồi (Respond): Kích hoạt biện pháp ngăn chặn (cô lập mạng, hủy tiến trình, xóa tệp) thông qua kịch bản tự động hoặc thao tác thủ công từ chuyên viên SOC.
- Tối ưu hóa và Cải tiến (Learn & Refine): Sau khi xử lý sự cố, các tri thức mới về biến thể tấn công được sử dụng để hiệu chỉnh tập luật (Rule tuning), loại bỏ cảnh báo giả (False Positives) và bổ sung các kỹ thuật phát hiện mới vào hệ thống.

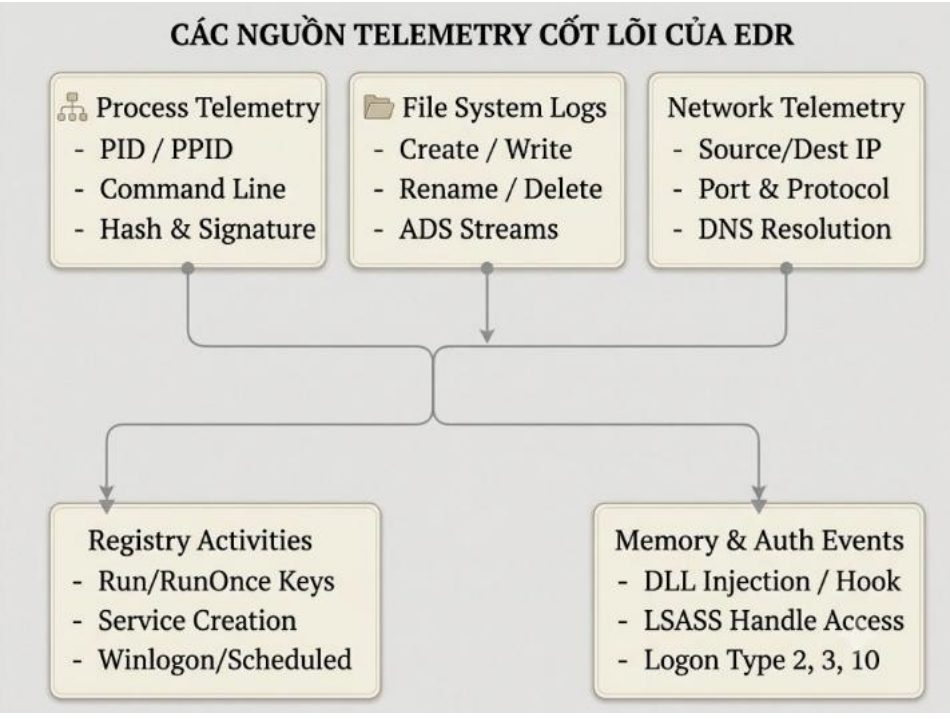
2.2. Cơ chế thu thập dữ liệu

Thu thập dữ liệu là lớp nền tảng trong kiến trúc EDR, bởi khả năng quan sát và phân tích phụ thuộc trực tiếp vào phạm vi cũng như chất lượng của dữ liệu được ghi nhận từ endpoint. Thay vì thu thập toàn bộ hoạt động của hệ thống một cách không chọn lọc, EDR tập trung vào các sự kiện có giá trị đối với việc giám sát an toàn thông tin, điều tra và phát hiện hành vi bất thường.

Khả năng phát hiện của EDR phụ thuộc hoàn toàn vào chất lượng, độ sâu và tính toàn vẹn của nguồn dữ liệu Telemetry thu thập từ máy trạm.

2.2.1. Thành phần và nguồn dữ liệu thu thập

Một giải pháp EDR toàn diện cần thu thập 5 nhóm sự kiện nền tảng trên hệ điều hành:



Dữ liệu tiến trình (Process Telemetry):

- Nội dung: Tên tiến trình, định danh tiến trình (PID), tiến trình cha (Parent PID - PPID), đường dẫn nhị phân (ImagePath), chuỗi tham số dòng lệnh đầy đủ (CommandLine), tài khoản thực thi (User/SID), mã băm tệp (MD5/SHA256) và trạng thái chữ ký số (Signature Status).
- Ý nghĩa: Là xương sống để dựng lại chuỗi thực thi (Process Execution Tree), phát hiện các kỹ thuật thực thi lệnh ngầm như powershell.exe -enc ... hay cmd.exe /c ....

Dữ liệu hệ thống tệp tin (File System Telemetry):

- Nội dung: Hành vi tạo tệp mới, sửa đổi nội dung, đổi tên, xóa tệp, thay đổi quyền truy cập (ACL) và các luồng dữ liệu phụ (Alternate Data Streams - ADS).
- Ý nghĩa: Giám sát việc ghi mã độc vào các thư mục tạm (%TEMP%, C:\Users\Public\), phát hiện hành vi mã hóa hàng loạt tệp tin của Ransomware hoặc hành vi ghi đè tệp hệ thống.

Dữ liệu kết nối mạng (Network Telemetry):

- Nội dung: Địa chỉ IP/Port nguồn và đích, giao thức (TCP/UDP), hướng kết nối (Inbound/Outbound), trạng thái kết nối và các bản ghi phân giải tên miền (DNS Queries/Responses).
- Ý nghĩa: Phát hiện kênh điều khiển máy chủ C2 (Command and Control), các hành vi trinh sát quét cổng nội bộ hoặc tải mã độc từ các tên miền độc hại.

Dữ liệu cấu hình hệ thống và Registry (Windows Registry Telemetry):

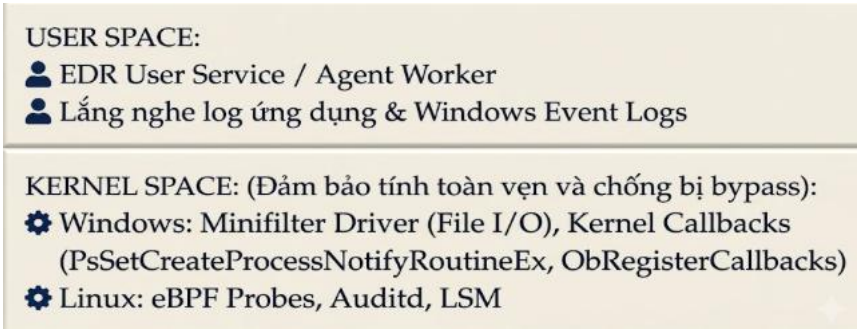
- Nội dung: Giám sát hành vi tạo mới, chỉnh sửa, xóa các Registry Keys và Values.
- Trọng tâm: Các khóa duy trì chỗ đứng (Persistence Keys) như Run, RunOnce, Services, Scheduled Tasks, Winlogon Helper DLLs, AppInit_DLLs.

Dữ liệu bộ nhớ và xác thực (Memory & Authentication Telemetry):

- Nội dung: Sự kiện nạp thư viện động (ImageLoad / DLL Load), hành vi mở tiến trình với quyền nguy hiểm (ProcessAccess - ví dụ tiến trình lạ đọc bộ nhớ của lsass.exe), sự kiện chèn mã vào bộ nhớ (VirtualAllocEx, WriteProcessMemory, CreateRemoteThread), và các sự kiện đăng nhập hệ thống (Logon Type 2 - Interactive, Type 3 - Network, Type 10 - RemoteInteractive/RDP).

2.2.2. Kỹ thuật thu thập tại endpoint

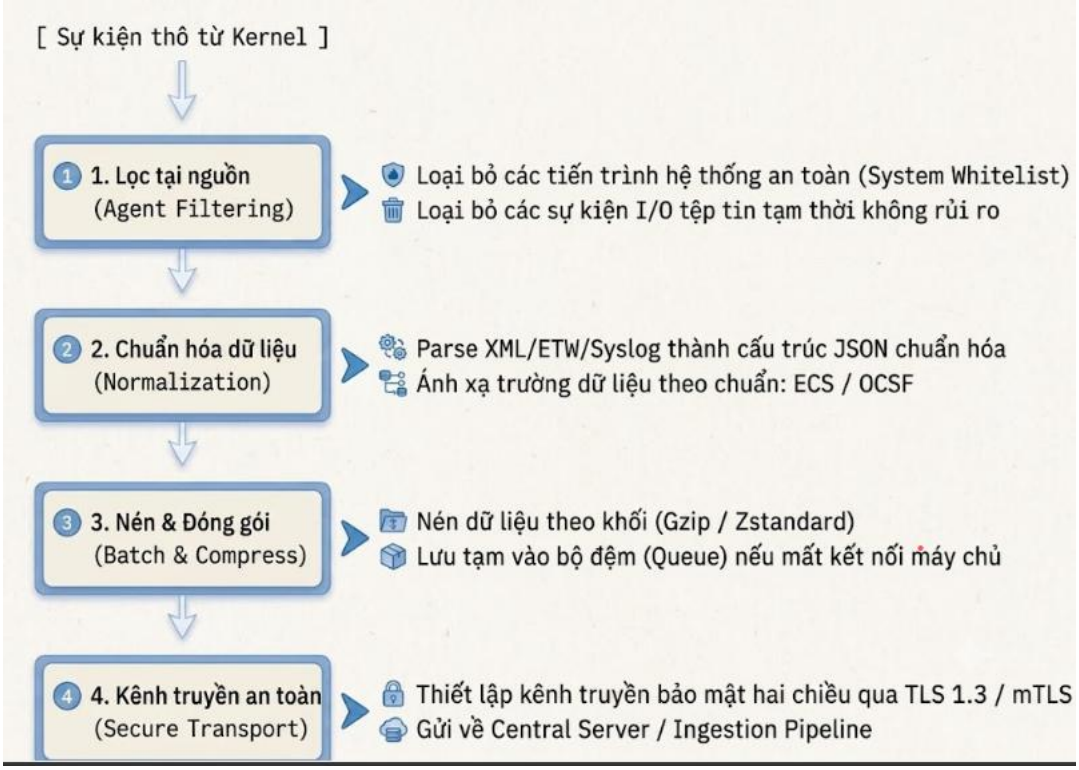
Để thu thập dữ liệu một cách tin cậy và ngăn chặn việc kẻ tấn công qua mặt hoặc làm giả dữ liệu, EDR phối hợp các cơ chế thu thập ở cả hai tầng:



- User-space: Thu thập thông qua các API mức cao và nhật ký sự kiện hệ thống. Ưu điểm là dễ triển khai và an toàn, nhưng có nguy cơ bị mã độc nâng cao vượt qua (unhooking hoặc direct syscalls).
- Kernel-space: Cài đặt các Driver mức nhân để bắt giữ sự kiện ngay từ gốc:
- Windows Kernel Callbacks: Sử dụng PsSetCreateProcessNotifyRoutineEx để đón bắt tiến trình ngay khi khởi tạo, ObRegisterCallbacks để ngăn chặn hành vi đọc trộm bộ nhớ tiến trình bảo mật như lsass.exe.
- File Minifilter Drivers: Can thiệp vào luồng I/O đọc/ghi tệp tin trước khi chạm đĩa cứng.
- Linux eBPF: Chạy các đầu dò an toàn trong nhân Linux để giám sát các lời gọi hệ thống (sys_execve, sys_connect) với hiệu năng cao.

2.2.3. Lọc, chuẩn hóa và truyền dữ liệu

Mỗi ngày, một máy trạm thông thường có thể sinh ra từ 100.000 đến hàng triệu sự kiện hệ thống. Việc đẩy toàn bộ dữ liệu thô về máy chủ sẽ gây quá tải mạng, cạn kiệt dung lượng lưu trữ và làm chậm quá trình phân tích. Do đó, cơ chế tiền xử lý tại Agent đóng vai trò sống còn:



Lọc thông minh tại nguồn (Source Filtering & Noise Reduction):

- Loại trừ các hành vi lặp đi lặp lại có tính chất lành tính đã được kiểm chứng (ví dụ: các luồng I/O tạm của trình duyệt, các tác vụ đọc tệp định kỳ của chính hệ điều hành).
- Ưu tiên thu thập sâu đối với các tiến trình nhạy cảm (powershell.exe, cmd.exe, wscript.exe, rundll32.exe, mshta.exe, anydesk.exe).

Chuẩn hóa dữ liệu (Data Normalization):

- Các sự kiện thô từ nhiều nguồn khác nhau (Windows Event Log, Sysmon, Linux Auditd, MacOS ESF) có định dạng và tên trường hoàn toàn khác nhau.
- Agent thực hiện chuẩn hóa về một cấu trúc dữ liệu chung (như chuẩn Elastic Common Schema - ECS hoặc Open Cybersecurity Schema Framework - OCSF). Ví dụ: tên tiến trình luôn được gán vào trường process.name, địa chỉ IP đích luôn là destination.ip.

Nén và truyền dữ liệu an toàn (Compression & Secure Transport):

- Dữ liệu được gom thành từng gói (Batching) và nén bằng các thuật toán nén nhanh (như Zstandard hoặc Gzip) để giảm thiểu từ 70% - 80% băng thông tiêu thụ trên đường truyền mạng.
- Toàn bộ dữ liệu được truyền qua kênh mã hóa an toàn TLS 1.3 kết hợp xác thực chứng chỉ hai chiều (Mutual TLS - mTLS), đảm bảo dữ liệu telemetry không thể bị nghe lén, giả mạo hoặc chèn mã độc trên đường truyền.

2.3. Cơ chế phân tích và phát hiện đe dọa

Cơ chế phát hiện của EDR đóng vai trò phân tích nguồn dữ liệu telemetry thu thập từ máy trạm để nhận diện các hoạt động đáng ngờ. Thay vì chỉ kiểm tra từng tệp tin riêng lẻ, EDR hiện đại kết hợp 4 cấp độ phân tích từ đơn giản đến nâng cao:

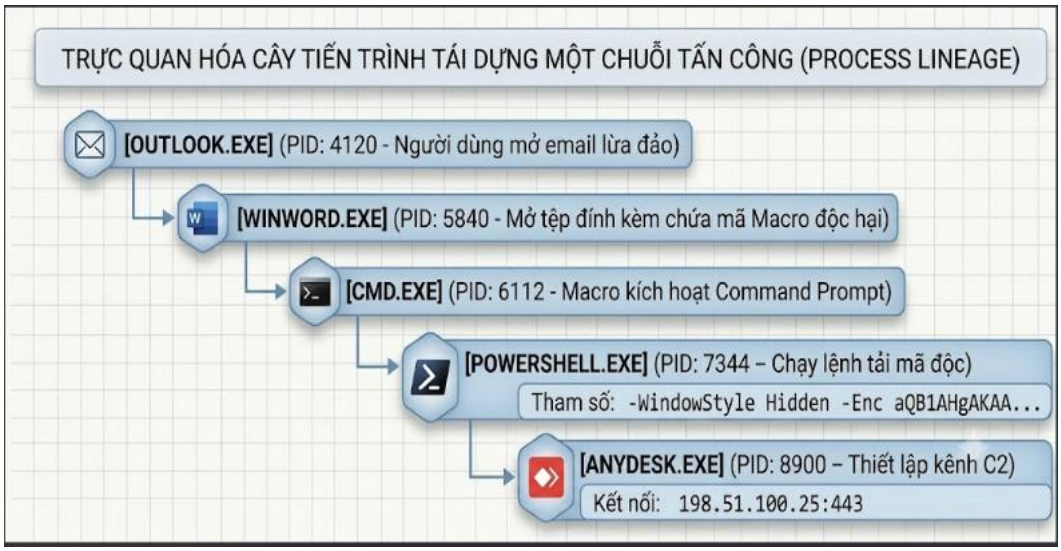


2.3.1. Phân tích dữ liệu và xây dựng ngữ cảnh

Một trong những hạn chế lớn nhất của việc phân tích log truyền thống là các sự kiện thường bị nhìn nhận một cách rời rạc và cô lập. Trong thực tế, một hành vi đơn lẻ (ví dụ: việc chạy lệnh whoami.exe hoặc gọi tiện ích certutil.exe) có thể là tác vụ quản trị thông thường của người quản trị mạng. Tuy nhiên, nếu lệnh đó được sinh ra từ một tiến trình độc hại, nó lập tức trở thành một mắt xích trong chuỗi trinh sát hoặc tải mã độc.

Do đó, nhiệm vụ đầu tiên của EDR là xây dựng ngữ cảnh thực thi bằng cách xâu chuỗi các sự kiện thông qua:

- Quan hệ Cha - Con (Parent-Child): Liên kết định danh tiến trình con (PID) với tiến trình cha đã tạo ra nó (PPID) để vẽ nên Cây tiến trình (Process Lineage Tree).
- Ngữ cảnh bổ sung: Phân tích tham số dòng lệnh (CommandLine), thư mục khởi chạy và quyền hạn tài khoản thực thi.



Nhờ cây tiến trình này, phân tích viên SOC có thể ngay lập tức truy ngược nguồn gốc của cuộc tấn công (bắt đầu từ tệp đính kèm trong Outlook) mà không mất hàng giờ tra cứu thủ công.

2.3.2. Phát hiện dựa trên quy tắc và chỉ dấu xâm phạm

Đây là tầng phát hiện tuyến đầu với tốc độ xử lý nhanh nhất, dựa trên việc so khớp dữ liệu telemetry với tập hợp tri thức tĩnh về các mối đe dọa đã được xác định trước.

Các loại chỉ dấu xâm phạm (Indicators of Compromise - IoC)

So khớp mã băm tệp (MD5/SHA256), địa chỉ IP máy chủ C2 hoặc tên miền độc hại với cơ sở dữ liệu danh sách đen (Blacklist).

Phát hiện dựa trên quy tắc tĩnh (Rule-based Detection)

Sử dụng các biểu thức chính quy (Regex) và logic so khớp chuỗi để phát hiện các câu lệnh quản trị có dấu hiệu nguy hiểm hoặc các công cụ tấn công phổ biến.

Ví dụ về Quy tắc phát hiện lệnh PowerShell bị làm rối (Chuẩn Sigma):

```
title: Suspicious PowerShell Base64 Encoded Command Execution
id: e4a6b2c1-8765-4321-abcd-ef0123456789
status: production
description: Phát hiện việc thực thi PowerShell với tham số mã hóa Base64 và chế độ ẩn cửa sổ
tags:
    - attack.execution
    - attack.t1059.001
    - attack.defense_evasion
```

```
    - attack.t1027
logsource:
    category: process_creation
    product: windows
detection:
    selection_image:
        Image|endswith: '\powershell.exe'
    selection_encoded:
        CommandLine|contains:
            - ' -enc '
            - ' -encodedcommand '
            - ' -e '
    selection_hidden:
        CommandLine|contains:
            - ' -w hidden '
            - ' -windowstyle hidden '
            - ' -noni '
    condition: selection_image and selection_encoded and selection_hidden
level: high
```

Ưu điểm: Tốc độ xử lý tức thì, độ chính xác cao đối với các mã độc và công cụ tấn công đã biết.

Hạn chế: Kẻ tấn công có thể dễ dàng né tránh bằng cách đổi tên tệp, thay đổi mã băm (thêm byte rác) hoặc làm rối chuỗi lệnh.

2.3.3. Phát hiện dựa trên chỉ số tấn công (IoA), phân tích hành vi và phát hiện bất thường

Để khắc phục nhược điểm của các quy tắc tĩnh, EDR chuyển dịch trọng tâm sang Indicators of Attack (IoA). Thay vì đặt câu hỏi "Tệp tin này có phải mã độc không?", EDR phân tích "Hành vi này có phải là một kỹ thuật tấn công hay không?".

SO SÁNH BẢN CHẤT PHÁT HIỆN: IoC vs IoA

IoC (Chỉ dấu xâm phạm tĩnh)	IoA (Chỉ số tấn công hành vi)
• **Hỏi:** File này có hash là gì? • **Kiểm tra:** IP này có trong blacklist? • **Điểm yếu:** Hacker đổi tên file, đổi IP/Domain trong 1 phút→BYPASS	• **Hỏi:** Tiến trình này đang làm gì? • **Kiểm tra:** Tiến trình có chèn mã vào bộ nhớ tiến trình khác không?
	• **Điểm mạnh:** Dù đổi tên/hash, hành vi tấn công không thể thay đổi!

Các nhóm hành vi bất thường phổ biến được EDR giám sát gồm:

- Can thiệp bộ nhớ (Process Injection): Một tiến trình tìm cách chèn mã độc vào không gian bộ nhớ của một tiến trình hệ thống hợp lệ đang chạy để ẩn mình.
- Đánh cắp thông tin xác thực (Credential Access): Một tiến trình lạ cố gắng đọc trích xuất mật khẩu từ bộ nhớ của tiến trình dịch vụ xác thực Windows (lsass.exe).
- Phá hủy cơ chế bảo vệ (Defense Evasion): Các hành vi cố tình tắt tính năng quét của Antivirus, xóa nhật ký sự kiện hệ thống hoặc xóa các bản sao lưu phục hồi dữ liệu (Shadow Copies).
- Phát hiện bất thường (Anomaly Detection): Nhận diện những hành vi sai lệch đột biến so với thói quen hoạt động bình thường (Baseline) của người dùng và thiết bị trong mạng.

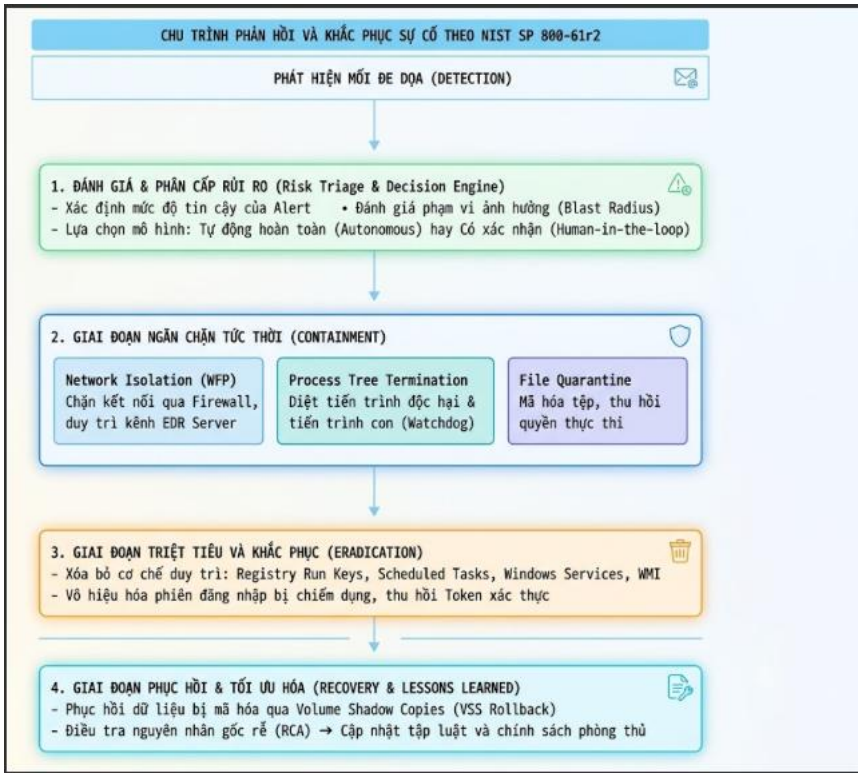
2.3.4. Tương quan sự kiện đa nguồn và đánh giá mức độ đe dọa

Một cuộc tấn công mạng thực tế thường diễn ra qua nhiều bước liên tiếp. Nếu chỉ đánh giá từng sự kiện riêng rẽ, hệ thống rất dễ bỏ sót hoặc tạo ra quá nhiều cảnh báo mức thấp gây quá tải (Alert Fatigue).

- Cơ chế tương quan: EDR gom các sự kiện xảy ra theo trình tự thời gian gắn liền với cùng một máy trạm:
- Sự kiện 1: PowerShell tải một tệp thực thi lạ về thư mục tạm.
- Sự kiện 2: Tạo khóa Registry khởi động cùng hệ điều hành (Persistence).
- Sự kiện 3: Tệp thực thi mở kết nối ra địa chỉ IP bên ngoài Internet.
- Đánh giá rủi ro: Khi 3 sự kiện này xảy ra nối tiếp nhau, hệ thống tương quan sẽ tự động cộng dồn điểm rủi ro và nâng mức cảnh báo lên Nghiêm trọng (Critical), đồng thời ánh xạ trực tiếp vào ma trận kỹ thuật MITRE ATT&CK để hỗ trợ đội ngũ an ninh phản ứng tức thời.

2.4. Cơ chế phản hồi và giảm thiểu sự cố

Sau khi phát hiện hoạt động đáng ngờ, hệ thống EDR lập tức kích hoạt các cơ chế phản hồi nhằm ngăn chặn hành vi phá hoại, cô lập mối đe dọa và hỗ trợ khôi phục trạng thái an toàn cho thiết bị đầu cuối. Cơ chế này được xây dựng bám sát theo hướng dẫn ứng cứu sự cố của Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST SP 800-61r2).



2.4.1. Đánh giá và lựa chọn phương án phản hồi

Không phải mọi sự kiện an ninh đều đòi hỏi mức độ can thiệp giống nhau. Một hành động can thiệp quá mạnh tay có thể làm gián đoạn các tiến trình nghiệp vụ sống còn của doanh nghiệp, trong khi một hành động quá nhẹ sẽ tạo điều kiện cho kẻ tấn công hoàn tất việc đánh cắp dữ liệu hoặc mã hóa hệ thống. Do đó, EDR thiết lập một Ma trận đánh giá rủi ro đa chiều để lựa chọn phương án phản hồi tối ưu:

a. Các tiêu chí đánh giá ngăn chặn theo chuẩn NIST

Theo NIST SP 800-61r2, việc quyết định áp dụng biện pháp ngăn chặn cần dựa trên 4 yếu tố cốt lõi:

- Thiệt hại tiềm tàng đối với tài nguyên (Potential damage to resources): Mối đe dọa có khả năng phá hủy dữ liệu, mã hóa tống tiền hay gây tê liệt hạ tầng hay không?
- Yêu cầu bảo toàn bằng chứng số (Evidence preservation): Hành động phản hồi có làm mất dấu vết trong bộ nhớ RAM hoặc nhật ký hệ thống phục vụ điều tra pháp y hay không?
- Tính sẵn sàng của dịch vụ (Service availability): Endpoint bị ảnh hưởng là máy trạm của người dùng cá nhân hay là máy chủ dịch vụ lõi (Domain Controller, Database, Web Server)?

- Thời gian và nguồn lực cần thiết (Time and resources required): Cần hành động tự động trong vài giây hay có đủ thời gian để chuyên viên SOC phân tích thủ công?

b. Phân cấp mức độ phản hồi trong hệ thống EDR

Cấp 1: Thông tin (Low) Thấp - Trung bình Chạy lệnh quản trị lạ (whoami, ipconfig), quét cổng nội bộ mức nhẹ. Ghi nhận Telemetry chi tiết, đánh dấu phiên làm việc để tiếp tục theo dõi. Giám sát thụ động (No Action)

Cấp 2: Cảnh báo (Medium) Trung bình Tải tệp thực thi từ nguồn không xác định, sửa đổi cấu hình phần mềm. Đẩy cảnh báo về SOC Console, tạm thời cách ly tệp nghi ngờ vào vùng đệm. Thông báo & Chờ phê duyệt

Cấp 3: Can thiệp tiến trình (High) Cao Phát hiện công cụ tấn công đã biết (Mimikatz, Procdump), sửa đổi Registry Run keys. Cưỡng chế dừng tiến trình (TerminateProcess), thu hồi khóa khởi động ngầm. Tự động hoặc 1-Click Action

Cấp 4: Khẩn cấp (Critical) Rất cao Ransomware đang mã hóa dữ liệu hàng loạt, thiết lập kênh điều khiển ngầm C2 qua AnyDesk (T1219). Cô lập toàn bộ máy trạm khỏi mạng nội bộ, tiêu diệt toàn bộ cây tiến trình liên quan. Tự động kích hoạt (Active Response)

2.4.2. Các kỹ thuật ngăn chặn trực tiếp tại Endpoint

EDR cung cấp 3 biện pháp can thiệp kỹ thuật trực tiếp và phổ biến nhất trên thiết bị đầu cuối:

- Chấm dứt tiến trình độc hại (Process Termination): Cưỡng chế dừng ngay lập tức tiến trình đang thực thi mã độc và toàn bộ các tiến trình con liên quan, ngăn không cho kẻ tấn công duy trì quyền thực thi lệnh.
- Cách ly tệp tin (File Quarantine): Mã hóa tệp tin đáng ngờ và di chuyển vào một thư mục cách ly an toàn (Vault). Biện pháp này vừa vô hiệu hóa khả năng tự thực thi lại của tệp, vừa bảo toàn mẫu nguyên vẹn phục vụ công tác phân tích mã độc và giám định số.
- Cô lập mạng máy trạm (Network Isolation): Tự động cấu hình lại tường lửa tại máy trạm để chặn toàn bộ kết nối mạng vào/ra (cả mạng LAN và Internet), ngăn chặn mã độc di chuyển ngang (Lateral Movement) hoặc truyền dữ liệu ra ngoài.

Điểm đặc biệt: EDR vẫn duy trì duy nhất kênh liên lạc bảo mật giữa Agent và EDR Server để chuyên viên an ninh có thể điều khiển từ xa và điều tra sự cố.

2.4.3. Phản hồi tự động kiểm soát cảnh báo sai

a. Kiến trúc của Engine phản hồi tự động (Active Response Engine)

Tính năng phản hồi tự động cho phép hệ thống chuyển từ trạng thái giám sát thụ động sang tự động hóa phòng thủ. Khi một quy tắc phát hiện mức độ nguy hiểm cao được kích

hoạt, máy chủ trung tâm sẽ gửi lệnh điều khiển (Command Dispatch) tới Agent trên máy trạm để kích hoạt một kịch bản phản ứng được lập trình sẵn.

Ví dụ cấu hình Active Response trên nền tảng Wazuh (ossec.conf):

```
<!-- 1. Định nghĩa lệnh thực thi kịch bản chặn tiến trình AnyDesk -->
<command>
  <name>kill-anydesk-process</name>
  <executable>active-response/bin/kill_process.cmd</executable>
  <timeout_allowed>no</timeout_allowed>
</command>
<!-- 2. Cấu hình kích hoạt tự động khi Rule phát hiện T1219 bị kích hoạt -->
<active-response>
  <command>kill-anydesk-process</command>
  <location>local</location>
  <rules_id>100101</rules_id> <!-- Rule ID phát hiện AnyDesk mở kết nối C2 -->
</active-response>
```

Nội dung kịch bản thực thi tại máy trạm (kill_process.cmd):

```
@echo off
```

Kịch bản Active Response tự động tiêu diệt tiến trình AnyDesk

```
taskkill /F /IM anydesk.exe /T >> "C:\Program Files (x86)\ossec-agent\active-response\active-responses.log" 2>&1
```

b. Vấn đề "Xung đột tự động hóa" và Kiểm soát cảnh báo sai (False Positive Controls)

Một trong những thách thức lớn nhất của Active Response là nguy cơ gián đoạn nghiệp vụ do cảnh báo sai (False Positive). Nếu hệ thống tự động cô lập mạng hoặc tắt tiến trình trên một máy chủ cơ sở dữ liệu giao dịch ngân hàng chỉ vì một script bảo trì định kỳ của quản trị viên, thiệt hại kinh tế có thể lớn hơn chính cuộc tấn công.

Để giải quyết bài toán này, EDR áp dụng hai cơ chế kiểm soát:

- Phân vùng chính sách theo vai trò thiết bị (Role-based Response Policies):
  - Nhóm máy trạm người dùng (End-user Workstations): Áp dụng chế độ tự động hoàn toàn (Zero-touch / Autonomous). Khi phát hiện mã độc, lập tức diệt tiến trình và cô lập mạng.

- Nhóm máy chủ hạ tầng trọng yếu (Critical Infrastructure / Domain Controllers): Áp dụng chế độ Bán tự động (Human-in-the-Loop). Hệ thống chỉ ghi nhận cảnh báo mức độ cao và gửi yêu cầu phê duyệt kèm nút bấm "Xác nhận Cô lập" tới màn hình của trực ban SOC.

o Cơ chế tự động hoàn nguyên sau khoảng thời gian Timeout (Temporary Action & Auto-rollback): Đối với các hành động như chặn IP hoặc khóa tài khoản, EDR cho phép thiết lập thời gian hết hạn (ví dụ: tự động mở khóa sau 30 phút). Nếu sau khoảng thời gian đó không phát hiện thêm hành vi đáng ngờ, hệ thống sẽ tự động đưa cấu hình về trạng thái ban đầu.

2.4.4. Điều tra sau phản hồi và khôi phục hệ thống

Phản hồi không kết thúc ở việc diệt tiến trình mà tiếp tục với các bước khắc phục chuyên sâu:

o Loại bỏ cơ chế duy trì (Persistence Eradication): Tự động truy quét và xóa bỏ các khóa Registry khởi động cùng hệ thống (Run/RunOnce), các tác vụ lên lịch ngầm (Scheduled Tasks) hoặc các dịch vụ Windows do kẻ tấn công tạo ra.

o Khôi phục trạng thái (Remediation & Rollback): Trong các vụ tấn công bằng Ransomware, EDR tận dụng các bản sao lưu bóng hệ thống (Volume Shadow Copies - VSS) hoặc snapshot độc quyền để tự động phục hồi các tệp dữ liệu bị mã hóa về trạng thái nguyên vẹn trước thời điểm bị tấn công.

2.5. Ứng dụng MITRE ATT&CK trong EDR

Trong kỷ nguyên an ninh mạng hiện đại, MITRE ATT&CK® (Adversarial Tactics, Techniques, and Common Knowledge) đã trở thành "tiêu chuẩn vàng" và là ngôn ngữ chung toàn cầu để mô hình hóa hành vi của các tác nhân đe dọa (Threat Actors). Đối với giải pháp EDR, MITRE ATT&CK đóng hai vai trò mang tính sống còn: (1) Thước đo chuẩn mực để đánh giá năng lực phát hiện và xác định điểm mù (Gap Analysis); và (2) Khung tham chiếu phương pháp luận để kỹ thuật hóa các tập luật phát hiện (Detection Engineering).

2.5.1. Cấu trúc của MITRE ATT&CK và mô tả hành vi tấn công

Khung MITRE ATT&CK tổ chức các kỹ thuật tấn công theo dạng ma trận phân cấp gồm:

o Tactics (Chiến thuật): Đại diện cho mục tiêu chiến lược của kẻ tấn công (như Initial Access, Execution, Persistence, Command and Control).

o Techniques (Kỹ thuật): Cách thức cụ thể để thực hiện mục tiêu chiến thuật. Mỗi kỹ thuật được gán một mã định danh duy nhất (ví dụ: T1059 cho Command/Scripting Interpreter, T1219 cho Remote Access Software).

- Procedures (Thủ tục thực thi): Cách một mã độc hoặc nhóm tin tặc cụ thể triển khai kỹ thuật trong thực tế.
- Data Sources (Nguồn dữ liệu giám sát): Chỉ rõ các thành phần dữ liệu cần thu thập (như Process Creation, Network Traffic) để phát hiện được kỹ thuật đó.

2.5.2. Quy trình chuẩn hóa và xây dựng Rule phát hiện bám sát TTPs

Quy trình kỹ thuật hóa luật phát hiện (Detection Engineering) theo chuẩn MITRE ATT&CK gồm 4 bước chính:

- Phân tích kỹ thuật tấn công: Nghiên cứu hành vi thực thi của công cụ (ví dụ: các cờ tham số chạy ngầm của AnyDesk như --install, --start-service, --silent).
- Xác định nguồn Telemetry: Cấu hình thu thập sự kiện tạo tiến trình (Sysmon Event ID 1) và kết nối mạng (Sysmon Event ID 3).
- Xây dựng luật phát hiện: Viết rule logic (bằng định dạng chuẩn Sigma hoặc XML trên Wazuh) và gắn thẻ định danh MITRE tương ứng:

```
<rule id="100100" level="10">
  <if_group>sysmon_process_creation</if_group>
  <field name="win.eventdata.image">anydesk.exe</field>
  <description>T1219 - Phát hiện khởi chạy phần mềm AnyDesk từ dòng lệnh</description>
  <mitre>
    <id>T1219</id>
  </mitre>
</rule>
```

- Kiểm thử và xác thực: Sử dụng công cụ mã nguồn mở Atomic Red Team để chạy các lệnh giả lập kỹ thuật T1219 trong môi trường Lab, đảm bảo hệ thống sinh cảnh báo chính xác với độ trễ thấp và không phát sinh cảnh báo sai.

2.6. Xu hướng EDR tích hợp AI & XDR

2.6.1. Ứng dụng Trí tuệ nhân tạo (AI) và Học máy trong EDR

AI và Học máy (Machine Learning) được ứng dụng ở nhiều tầng của hệ thống EDR nhằm khắc phục các nhược điểm của quy tắc tĩnh:

- Học máy tại máy trạm (On-agent ML): Đánh giá cấu trúc tệp tin tĩnh (PE features, Opcode, Entropy) để phân loại và ngăn chặn mã độc mới (Zero-day) trước khi thực thi với độ trễ cực thấp.

- Phát hiện bất thường hành vi (Anomaly Detection & UEBA): Tự động học thói quen hoạt động bình thường (Baseline) của người dùng và thiết bị, từ đó nhận diện các hành vi sai lệch đột biến mà không phụ thuộc vào dấu hiệu nhận dạng có sẵn.
- Mô hình Ngôn ngữ và Trợ lý AI (LLMs in SOC): Tự động giải mã các câu lệnh PowerShell/Script bị làm rối phức tạp, hỗ trợ tóm tắt chuỗi sự kiện sự cố và cho phép chuyên viên an ninh thực hiện truy vấn săn lùng mối đe dọa (Threat Hunting) bằng ngôn ngữ tự nhiên.

Thách thức: Mặc dù AI mang lại hiệu quả cao nhưng vẫn tồn tại những rào cản như vấn đề "hộp đen" (khó giải thích lý do cảnh báo phục vụ điều tra số) và nguy cơ bị kẻ tấn công đánh lừa bằng các kỹ thuật đối kháng (Adversarial AI). Do đó, các nền tảng EDR hiện đại luôn kết hợp AI như một lớp bổ trợ song hành cùng các quy tắc phát hiện dựa trên MITRE ATT&CK.

2.6.2. Xu hướng tiến hóa từ EDR lên Nền tảng XDR

Giới hạn của EDR đơn lẻ: EDR truyền thống chỉ tập trung vào các thiết bị có thể cài đặt Agent, tạo ra các "điểm mù" đối với thiết bị mạng (Router/Switch), thiết bị IoT và lưu lượng đám mây.

Sự ra đời của XDR: XDR là bước tiến hóa tự nhiên, hợp nhất luồng dữ liệu Telemetry từ nhiều nguồn: Endpoint (EDR) + Mạng (NDR) + Điện toán đám mây (Cloud) + Hệ thống định danh (Identity/Active Directory).

Ưu thế vượt trội của XDR:

Tự động tương quan các mắt xích tấn công diễn ra trên nhiều nền tảng thành một chuỗi sự cố thống nhất.

Cho phép phản hồi đồng bộ đa điểm (vừa cô lập máy trạm, vừa khóa tài khoản người dùng, vừa chặn IP trên tường lửa mạng).

Định vị nền tảng Wazuh: Nền tảng mã nguồn mở Wazuh được lựa chọn trong đề tài nghiên cứu là giải pháp tiêu biểu đại diện cho xu hướng này khi kết hợp hài hòa năng lực EDR (giám sát sâu tại máy trạm) với năng lực XDR/SIEM (tổng hợp log hạ tầng mạng và đám mây đa dạng).

2.7. Tổng kết chương 2

Chương 2 đã đi sâu phân tích cơ sở lý thuyết và kiến trúc kỹ thuật cốt lõi của giải pháp EDR, làm rõ cách thức một hệ thống EDR vận hành từ khâu thu thập dữ liệu đến khâu phản hồi sự cố:

- Kiến trúc tổng thể: EDR được xây dựng trên mô hình phân tầng gồm Endpoint Agent và Central Backend Analytics Engine, vận hành theo một chu trình xử lý khép kín sáu

giai đoạn (Thu thập – Chuẩn hóa – Phân tích – Cảnh báo – Phản hồi – Tối ưu hóa), cho phép hệ thống không ngừng học hỏi để nâng cao năng lực phòng thủ.

- Cơ chế thu thập dữ liệu: Chất lượng phát hiện của EDR phụ thuộc trực tiếp vào phạm vi và độ sâu của dữ liệu telemetry (tiến trình, tệp tin, mạng, Registry, bộ nhớ/xác thực), được thu thập bằng các kỹ thuật ở cả tầng user-space lẫn kernel-space, sau đó được lọc nhiễu, chuẩn hóa và truyền tải an toàn về máy chủ trung tâm.
- Cơ chế phân tích và phát hiện: EDR kết hợp nhiều tầng phát hiện, từ so khớp chỉ dấu xâm phạm (IoC) và quy tắc tĩnh tốc độ cao, đến phân tích hành vi dựa trên chỉ số tấn công (IoA) và tương quan sự kiện đa nguồn, nhằm khắc phục hạn chế của các phương pháp phát hiện đơn lẻ và giảm thiểu tình trạng quá tải cảnh báo (Alert Fatigue).
- Cơ chế phản hồi và giảm thiểu sự cố: Dựa trên các tiêu chí đánh giá rủi ro theo chuẩn NIST SP 800-61r2, EDR phân cấp mức độ phản hồi tương ứng với từng loại nguy cơ, đồng thời cung cấp các biện pháp ngăn chặn trực tiếp (chấm dứt tiến trình, cách ly tệp, cô lập mạng), có kiểm soát cảnh báo sai theo vai trò thiết bị, và hỗ trợ điều tra, khôi phục hệ thống sau sự cố.
- Vai trò của MITRE ATT&CK: Khung MITRE ATT&CK đóng vai trò là ngôn ngữ chung để mô hình hóa hành vi tấn công (Tactics – Techniques – Procedures – Data Sources), là nền tảng phương pháp luận giúp xây dựng và chuẩn hóa các rule phát hiện bám sát chiến thuật, kỹ thuật của kẻ tấn công.
- Xu hướng phát triển: Sự tích hợp AI/Machine Learning giúp EDR khắc phục hạn chế của quy tắc tĩnh, đồng thời xu hướng tiến hóa từ EDR lên nền tảng XDR mở rộng phạm vi giám sát ra ngoài endpoint, hợp nhất dữ liệu từ mạng, đám mây và hệ thống định danh — trong đó Wazuh được xác định là nền tảng đại diện tiêu biểu cho xu hướng này.

CHƯƠNG 3. THỰC NGHIỆM TRIỂN KHAI GIẢI PHÁP EDR (WAZUH)

3.1. Giới thiệu nền tảng mã nguồn mở Wazuh

3.1.1. Tổng quan về Wazuh và lý do lựa chọn trong nghiên cứu

Wazuh là một nền tảng an ninh mạng mã nguồn mở hàng đầu thế giới, hợp nhất hai năng lực SIEM (Security Information and Event Management) và XDR/EDR (Extended Endpoint Detection and Response) trong cùng một kiến trúc thống nhất. Được phát triển từ năm 2015 dựa trên nền tảng của dự án OSSEC HIDS trước đây, Wazuh đã được hiện đại hóa toàn diện với khả năng mở rộng quy mô lớn, hỗ trợ phân tích dữ liệu phân tán và tích hợp trực tiếp khung tham chiếu MITRE ATT&CK.

Wazuh được lựa chọn làm đối tượng nghiên cứu thực nghiệm của đề tài nhờ các ưu điểm:

- Mã nguồn mở và miễn phí: Cho phép triển khai thực nghiệm toàn diện mà không phụ thuộc vào chi phí bản quyền.
- Năng lực giám sát Endpoint chuyên sâu: Khi kết hợp cùng Microsoft Sysmon, Wazuh đóng vai trò như một giải pháp EDR hoàn chỉnh, ghi nhận chi tiết cây tiến trình (PID/PPID), dòng lệnh thực thi, thay đổi Registry và kết nối mạng.
- Tích hợp sẵn khung MITRE ATT&CK: Tự động phân loại và ánh xạ mọi cảnh báo theo các kỹ thuật TTPs chuẩn quốc tế.
- Hỗ trợ phản hồi tự động (Active Response): Cho phép tự động thực thi các hành động ngăn chặn (như hủy tiến trình độc hại) ngay khi phát hiện tấn công.

3.1.2. Kiến trúc tổng quan

Hạ tầng Wazuh được xây dựng theo kiến trúc phân tán gồm 4 thành phần chính:

- Wazuh Agent: Tiến trình dịch vụ chạy nền trên endpoint máy trạm. Agent chịu trách nhiệm thu thập log từ Windows Event Log, Sysmon, đọc thay đổi tệp tin và định kỳ gửi dữ liệu về Manager qua kênh mã hóa an toàn trên cổng TCP 1514.
- Wazuh Server (Manager): Là thành phần trung tâm đóng vai trò "bộ não" phân tích. Chứa các daemon chính:
    - wazuh-remoted: Lắng nghe và tiếp nhận luồng dữ liệu từ hàng nghìn Agent.
    - wazuh-analysisd: Thực hiện phân tích cú pháp dữ liệu thô thông qua các bộ giải mã (Decoders), so khớp với tập luật (Rules), tính toán mức độ nghiêm trọng (Level 0 đến 16) và sinh ra cảnh báo.
    - wazuh-execd: Quản lý và điều phối các kịch bản phản hồi tự động.

- Wazuh Indexer: Công cụ lưu trữ và tìm kiếm dữ liệu phân tán hiệu năng cao (dựa trên nhân OpenSearch). Indexer nhận các bản ghi cảnh báo dạng JSON từ Manager, đánh chỉ mục và lưu trữ theo từng ngày (wazuh-alerts-4.x-YYYY.MM.DD).
- Wazuh Dashboard: Giao diện điều khiển Web trực quan, cung cấp các dashboard chuyên dụng để theo dõi cảnh báo theo thời gian thực, quản trị danh sách Agent, tra cứu dữ liệu pháp chứng số và ánh xạ cảnh báo trực tiếp lên bảng nhiệt MITRE ATT&CK Navigator.

3.1.3. Các module chức năng EDR chính của Wazuh

Module Phân tích Log và Phát hiện xâm nhập (Log Analysis & Detection): Thu nạp và phân tích thời gian thực mọi sự kiện hệ thống, hỗ trợ tương quan đa sự kiện thông qua các thẻ <if_sid> và <if_matched_sid>.

Module Giám sát toàn vẹn tệp tin (File Integrity Monitoring - FIM / syscheck): Theo dõi liên tục các thay đổi trên tệp tin (tạo mới, sửa đổi nội dung, thay đổi quyền truy cập, xóa tệp) trong các thư mục trọng yếu (System32, Program Files, %TEMP%).

Module Đánh giá cấu hình an ninh (Security Configuration Assessment - SCA): Tự động quét và đối chiếu cấu hình hệ điều hành với các tiêu chuẩn đóng cứng bảo mật quốc tế (CIS Benchmarks).

Module Phát hiện lỗ hổng phần mềm (Vulnerability Detector): Đối chiếu danh mục phần mềm đã cài đặt trên máy trạm với cơ sở dữ liệu lỗ hổng bảo mật quốc gia (NVD - National Vulnerability Database) để cảnh báo các phần mềm chứa lỗ hổng CVE nguy hiểm.

Module Phản hồi tự động (Active Response): Tự động kích hoạt các kịch bản can thiệp (chặn IP bằng Firewall, tiêu diệt tiến trình độc hại) ngay khi xuất hiện cảnh báo đạt ngưỡng nguy hiểm định sẵn.

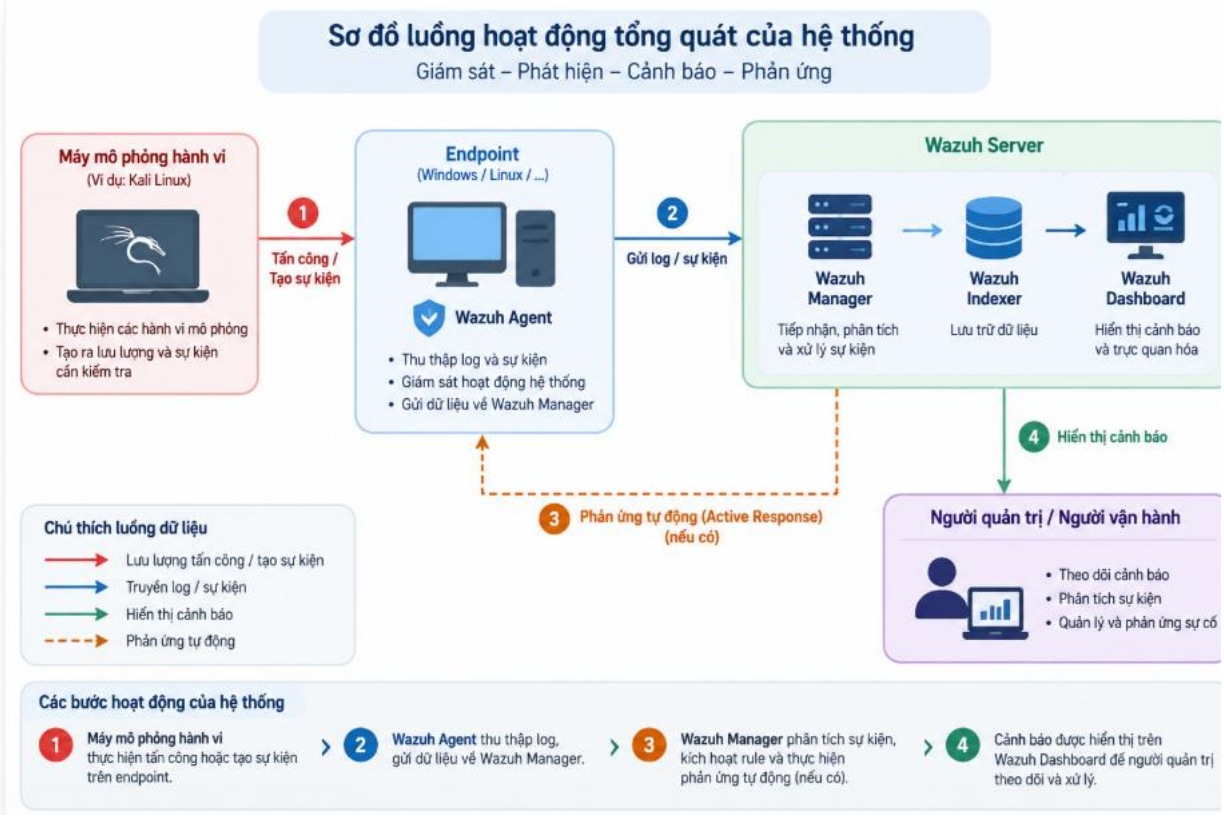
3.2. Mô hình và môi trường thực nghiệm

3.2.1. Mô hình thực nghiệm

Mô hình thực nghiệm được xây dựng nhằm đánh giá khả năng của Wazuh trong việc giám sát, phát hiện và phản ứng đối với các sự kiện bảo mật trên endpoint. Hệ thống gồm một máy chủ triển khai Wazuh, các endpoint được cài đặt Wazuh Agent và một hoặc nhiều máy được sử dụng để mô phỏng các hành vi cần kiểm tra.

Trong mô hình, Wazuh Manager đóng vai trò trung tâm trong việc tiếp nhận, phân tích và quản lý các sự kiện được gửi từ các endpoint. Wazuh Agent được triển khai trên các endpoint nhằm thu thập thông tin và sự kiện phát sinh trong quá trình hoạt động của hệ thống, sau đó gửi dữ liệu về Wazuh Manager. Các cảnh báo được phân tích và hiển thị trên Wazuh Dashboard, hỗ trợ việc theo dõi và đánh giá các sự kiện bảo mật.

Đối với các kịch bản có yêu cầu phản ứng tự động, Wazuh sử dụng cơ chế Active Response để thực hiện hành động xử lý tương ứng trên endpoint khi điều kiện của rule được đáp ứng.



3.2.2. Môi trường thực nghiệm

Môi trường thực nghiệm được triển khai trên các máy ảo nhằm tạo môi trường độc lập, thuận tiện cho việc xây dựng và kiểm tra các kịch bản bảo mật. Các thành phần chính của hệ thống bao gồm:

Thành phần	Vai trò
Wazuh server	Cung cấp các thành phần quản lý, phân tích, lưu trữ và hiển thị dữ liệu của Wazuh
Endpoint	Thiết bị được giám sát, có cài đặt Wazuh agent
Máy mô phỏng hành vi	Thực hiện các hành vi được xây dựng trong từng kịch bản thực nghiệm

Tùy thuộc vào từng kịch bản, endpoint có thể sử dụng Windows, Linux hoặc các nền tảng được Wazuh Agent hỗ trợ. Các nguồn dữ liệu được thu thập cũng được lựa chọn phù hợp với đặc điểm của từng hệ điều hành và yêu cầu phát hiện của kịch bản.

Các custom rule, CDB, Active Response và những cấu hình bổ sung được xây dựng riêng cho từng kịch bản. Việc tách cấu hình theo kịch bản giúp xác định rõ thành phần được

sử dụng để phát hiện và xử lý từng loại sự kiện, đồng thời thuận tiện cho quá trình đánh giá kết quả thực nghiệm.

3.2.3. Quy trình hoạt động

Trong mỗi kịch bản, một hành vi hoặc sự kiện cần kiểm tra được tạo ra trên endpoint hoặc từ máy mô phỏng hành vi. Wazuh Agent thu thập các dữ liệu liên quan và gửi về Wazuh Manager để phân tích. Hệ thống sử dụng các rule đã được cấu hình để xác định và phân loại sự kiện, từ đó tạo cảnh báo trên Wazuh Dashboard.

Đối với các kịch bản có triển khai cơ chế phản ứng tự động, khi sự kiện thỏa mãn điều kiện của rule, Active Response sẽ được kích hoạt để thực hiện hành động tương ứng trên endpoint. Kết quả phát hiện và phản ứng được kiểm tra, đối chiếu với mục tiêu của từng kịch bản để đánh giá khả năng đáp ứng của giải pháp EDR.

3.3. Thực nghiệm triển khai giải pháp

Thực hiện mô phỏng một số hành vi có khả năng xảy ra trên máy trạm nhằm đánh giá khả năng phát hiện, cảnh báo và ngăn chặn của hệ thống EDR/Wazuh. Các tình huống được thực hiện trong môi trường lab nhằm kiểm tra khả năng giám sát endpoint, phát hiện sự kiện dựa trên rule và thực thi cơ chế Active Response.

a. Mục tiêu

Kịch bản được xây dựng nhằm kiểm tra khả năng của Wazuh trong việc phát hiện hoạt động truy cập từ xa thông qua AnyDesk trên endpoint. Trong thực tế, AnyDesk là một công cụ hỗ trợ điều khiển máy tính từ xa, tuy nhiên việc sử dụng công cụ này mà không được cho phép có thể tạo ra nguy cơ mất kiểm soát endpoint hoặc bị truy cập trái phép. Vì vậy, hệ thống cần có khả năng ghi nhận sự kiện liên quan đến AnyDesk, phát hiện hoạt động bất thường và tạo cảnh báo để người quản trị kịp thời xử lý.

b. Cấu hình môi trường

Kịch bản được triển khai trên các máy ảo trong cùng môi trường mạng thực nghiệm. Các thành phần tham gia gồm Wazuh Server, endpoint được giám sát và máy thực hiện truy cập từ xa.

Thiết bị	Hệ điều hành	Địa chỉ IP
Wazuh server	Ubuntu Server	192.168.56.10/24
Endpoint Agent	Windows	192.168.56.20/24
Máy mô phỏng tấn công	Kali Linux	192.168.56.30/24

c. Cấu hình Active Response trên Windows Endpoint

Trên Windows Endpoint, cấu hình cơ chế Active Response thông qua hai tệp wazuh-edr-block.cmd và wazuh-edr-block.ps1. Tệp .cmd có nhiệm vụ khởi chạy script PowerShell khi nhận được yêu cầu thực thi Active Response từ Wazuh.

```
@echo off
setlocal

set "SCRIPT=%~dp0wazuh-edr-block.ps1"
set "LOG_FILE=C:\Program Files (x86)\ossec-agent\active-response\active-responses.log"

echo [%DATE% %TIME%] [wazuh-edr-block.cmd] Active Response launcher started >>
"%LOG_FILE%"

powershell.exe -NoProfile -NonInteractive -ExecutionPolicy Bypass -File "%SCRIPT%"

set "EXIT_CODE=%ERRORLEVEL%"

echo [%DATE% %TIME%] [wazuh-edr-
block.cmd] PowerShell exit code: %EXIT_CODE% >> "%LOG_FILE%"

exit /b %EXIT_CODE%
```

File thực hiện gọi wazuh-edr-block.ps1 bằng PowerShell và ghi nhận trạng thái thực thi vào file log.

```
$ErrorActionPreference = "Stop"
$LogFile = "C:\Program Files (x86)\ossec-agent\active-response\active-responses.log"
$RemoteAccessProcesses = @(
   "AnyDesk",
   "TeamViewer",
   "UltraViewer",
   "RustDesk"
)
$FirewallPrefix = "Wazuh-EDR-Block"
function Write-ARLog {
   param(
      [string]$Message
   )
   try {
      $Timestamp = Get-Date -Format "yyyy-MM-dd HH:mm:ss"
      Add-Content `
         -Path $LogFile `
         -Value "[$Timestamp] [wazuh-edr-block.ps1] $Message" `
         -Encoding UTF8
   }
   catch {
      # Do not terminate the Active Response only because
```

```
        # logging failed.
    }
}
Write-ARLog "================================================="
Write-ARLog "Active Response started"
try {
    $JsonLine = [Console]::In.ReadLine()
    if ([string]::IsNullOrWhiteSpace($JsonLine)) {
        Write-ARLog "ERROR: No JSON input received from Wazuh."
        exit 10
    }
    Write-ARLog "Received Wazuh alert."
}
catch {
    Write-ARLog "ERROR: Failed to read STDIN. $($_.Exception.Message)"
    exit 11
}
try {
    $Alert = $JsonLine | ConvertFrom-Json
}
catch {
    Write-ARLog "ERROR: Invalid JSON received."
    Write-ARLog "JSON parsing error: $($_.Exception.Message)"
    exit 12
}
$Command = $Alert.command
Write-ARLog "Command received: $Command"
if ($Command -ne "add") {
    Write-ARLog "Command is not 'add'. No action performed."
    exit 0
}
$RuleId = $null
try {
    $RuleId = $Alert.parameters.alert.rule.id
}
catch {
    $RuleId = "unknown"
}
Write-ARLog "Triggering Rule ID: $RuleId"
$SourceIP = $null
try {
    $SourceIP = $Alert.parameters.alert.data.win.eventdata.sourceIp
}
catch {
    $SourceIP = $null
}
if ([string]::IsNullOrWhiteSpace($SourceIP)) {
```

```
    Write-ARLog "ERROR: win.eventdata.sourceIp was not found."
    exit 20
}
$SourceIP = $SourceIP.Trim()
Write-ARLog "Detected source IP: $SourceIP"
$IPv4Regex = '^(25[0-5]|2[0-4][0-9]|1?[0-9]?[0-9])(\.(25[0-5]|2[0-4][0-9]|1?[0-9]?[0-
9])){3}$'
if ($SourceIP -notmatch $IPv4Regex) {
    Write-ARLog "ERROR: Invalid IPv4 address: $SourceIP"
    exit 21
}
if ($SourceIP -eq "127.0.0.1") {
    Write-ARLog "SAFETY: Source IP is localhost. Blocking skipped."
    exit 0
}
Write-ARLog "Starting remote-access process termination."
foreach ($ProcessName in $RemoteAccessProcesses) {
    try {
        $Processes = Get-Process -Name $ProcessName -ErrorAction SilentlyContinue
        if ($null -ne $Processes) {
            foreach ($Process in $Processes) {
                Write-ARLog "Terminating process: $ProcessName (PID $($Process.Id))"
                Stop-Process `
                    -Id $Process.Id `
                    -Force `
                    -ErrorAction Stop
                Write-ARLog "Successfully terminated: $ProcessName (PID $($Process.Id))"
            }
        }
        else {
            Write-ARLog "Process not running: $ProcessName"
        }
    }
    catch {
        Write-ARLog "ERROR terminating $ProcessName : $($_.Exception.Message)"
    }
}
$FirewallRuleName = "$FirewallPrefix-$SourceIP"
Write-ARLog "Firewall rule name: $FirewallRuleName"
try {
    $ExistingRule = Get-NetFirewallRule `
        -DisplayName $FirewallRuleName `
        -ErrorAction SilentlyContinue
    if ($null -eq $ExistingRule) {
        Write-ARLog "Creating firewall block for $SourceIP"
        New-NetFirewallRule `
            -DisplayName $FirewallRuleName `
```

```
            -Description "Wazuh EDR
- Unauthorized Remote Access detected by Rule $RuleId" `
            -Direction Inbound `
            -Action Block `
            -RemoteAddress $SourceIP `
            -Profile Any `
            -Enabled True `
            -ErrorAction Stop | Out-Null
        Write-ARLog "SUCCESS: Firewall blocked source IP $SourceIP"
    }
    else {
        Write-ARLog "Firewall rule already exists for $SourceIP"
    }
}
catch {
    Write-ARLog "ERROR: Failed to create firewall rule for $SourceIP"
    Write-ARLog "Firewall error: $($_.Exception.Message)"
    exit 30
}
try {
    $FirewallAddress = Get-NetFirewallRule `
        -DisplayName $FirewallRuleName `
        -ErrorAction Stop |
        Get-NetFirewallAddressFilter `
        -ErrorAction Stop
    Write-ARLog "Firewall verification:"
    Write-ARLog "RemoteAddress = $($FirewallAddress.RemoteAddress)"
}
catch {
    Write-ARLog "WARNING: Firewall rule was created but verification failed."
}
Write-ARLog "Active Response completed successfully."
Write-ARLog "Source IP $SourceIP has been processed."
Write-ARLog "================================================="
exit 0
```

Script PowerShell thực hiện các chức năng chính gồm tiếp nhận cảnh báo JSON từ Wazuh, xác định Rule ID và địa chỉ IP nguồn, kiểm tra tính hợp lệ của địa chỉ IP, kết thúc các tiến trình remote access đang hoạt động và tạo rule Windows Firewall để chặn địa chỉ IP nguồn.

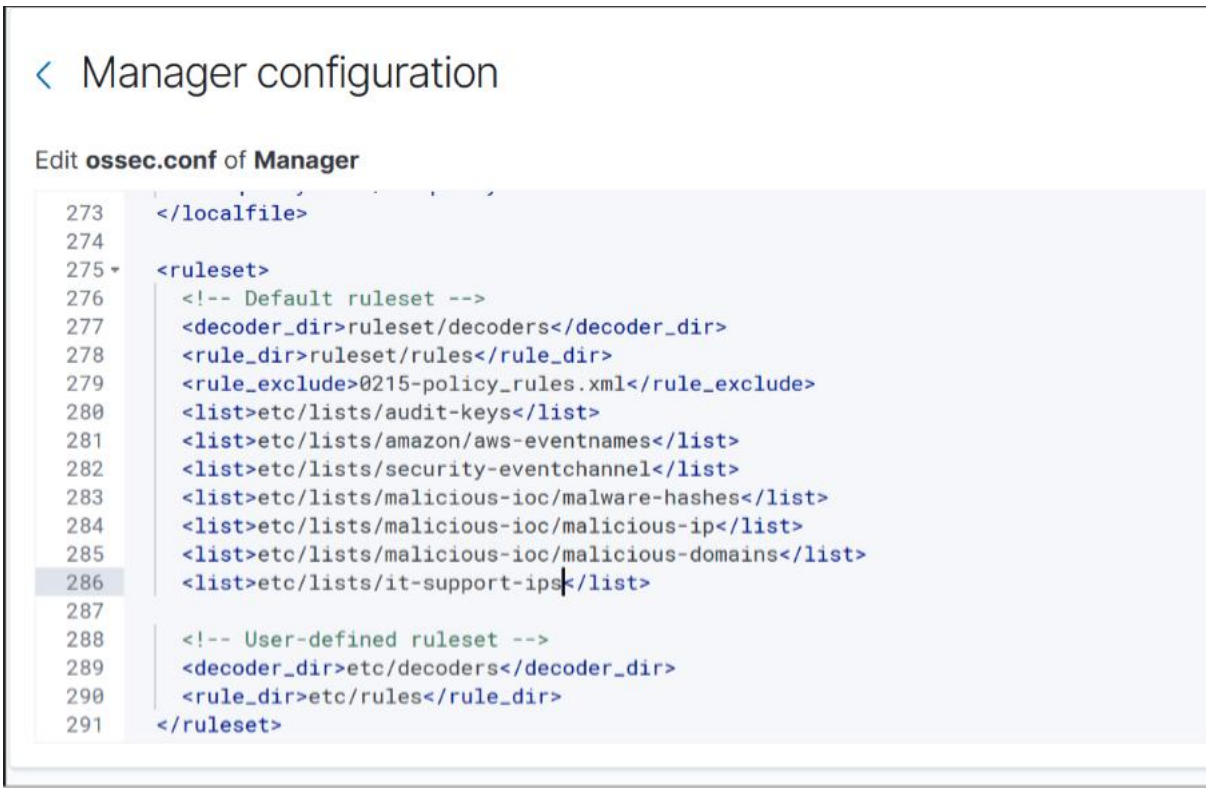
Danh sách $RemoteAccessProcesses bao gồm AnyDesk, TeamViewer, UltraViewer và RustDesk, cho phép script xử lý nhiều phần mềm remote access. Khi phát hiện tiến trình tương ứng, script sử dụng Stop-Process để kết thúc tiến trình. Sau đó, địa chỉ IP nguồn được sử dụng để tạo rule Firewall với hướng Inbound và hành động Block.

d. Cấu hình phát hiện truy cập trái phép trên Wazuh

Để phân biệt giữa các kết nối remote access được phép và không được phép, xây dựng danh sách it-support-ips chứa các địa chỉ IP được phép truy cập từ xa. Danh sách được khai báo trong cấu hình Wazuh để sử dụng trong quá trình đối chiếu địa chỉ IP nguồn.



Sau khi tạo danh sách, khai báo CDB List trong ossec.conf và thực hiện phân quyền cần thiết trước khi sử dụng trong các rule.



Trong local_rules.xml, xây dựng hai rule để phân biệt kết nối hợp lệ và không hợp lệ. Rule 100499 sử dụng CDB List để xác định các địa chỉ IP thuộc IT Support và loại khỏi quá trình cảnh báo. Ngược lại, Rule 100500 sử dụng not_address_match_key để phát hiện các địa chỉ IP không thuộc danh sách được phép. Rule này tạo cảnh báo mức 12 và được gắn với kỹ thuật MITRE ATT&CK T1219.

```
<group name="sysmon,remote_access,custom_remote_access,">

 <rule id="100499" level="0">

   <if_group>windows</if_group>
```

```
    <field name="win.system.eventID">^3$</field>

    <field name="win.eventdata.image" type="pcre2">(?i).*(anydesk|teamviewer|ultraviewer
|rustdesk)\.exe$</field>

    <field name="win.eventdata.destinationPort">^7070$</field>

    <field name="win.eventdata.initiated">^false$</field>

    <list field="win.eventdata.sourceIp" lookup="address_match_key">etc/lists/it-support-
ips</list>

    <description>Authorized Remote Access from IT Support ($(win.eventdata.sourceIp))</d
escription>

    <options>no_log</options>

  </rule>

  <rule id="100500" level="12">

    <if_group>windows</if_group>

    <field name="win.system.eventID">^3$</field>

    <field name="win.eventdata.image" type="pcre2">(?i).*(anydesk|teamviewer|ultraviewer
|rustdesk)\.exe$</field>

    <field name="win.eventdata.destinationPort">^7070$</field>

    <field name="win.eventdata.initiated">^false$</field>

    <field name="win.eventdata.sourceIp" type="pcre2">^(?!127\.0\.0\.1$).+</field>

    <list field="win.eventdata.sourceIp" lookup="not_address_match_key">etc/lists/it-
support-ips</list>

    <description>T1219
- Unauthorized Remote Access from $(win.eventdata.sourceIp)</description>

    <group>
      attack,
      attack.t1219,
      remote_access,
      anydesk,
    </group>
```

```
  <mitre>
    <id>T1219</id>
  </mitre>

 </rule>

</group>
```

Các điều kiện eventID = 3, tiến trình remote access, destinationPort = 7070 và initiated = false được sử dụng để xác định loại sự kiện cần phát hiện. Việc kết hợp với CDB List giúp hệ thống chỉ tạo cảnh báo đối với các kết nối có địa chỉ IP nguồn không được cho phép.

e. Cấu hình và liên kết Active Response

Sau khi xây dựng Rule 100500, cấu hình Active Response để tự động thực thi chương trình wazuh-edr-block.cmd khi rule này được kích hoạt.

```
<command>
  <name>wazuh-edr-block</name>
  <executable>wazuh-edr-block.cmd</executable>
  <timeout_allowed>no</timeout_allowed>
 </command>

 <active-response>
  <disabled>no</disabled>
  <command>wazuh-edr-block</command>
  <location>local</location>
  <rules_id>100500</rules_id>
 </active-response>
```

Cấu hình trên liên kết Rule 100500 với command wazuh-edr-block. Khi phát hiện truy cập remote access trái phép, Wazuh thực thi chương trình Active Response trên Windows Endpoint.

Đồng thời, Rule 100501 được xây dựng để ghi nhận sự kiện khi wazuh-edr-block.cmd được thực thi. Rule này được sử dụng để xác nhận Active Response đã được kích hoạt trong quá trình thực nghiệm.

```
<group name="active_response,edr,custom,">

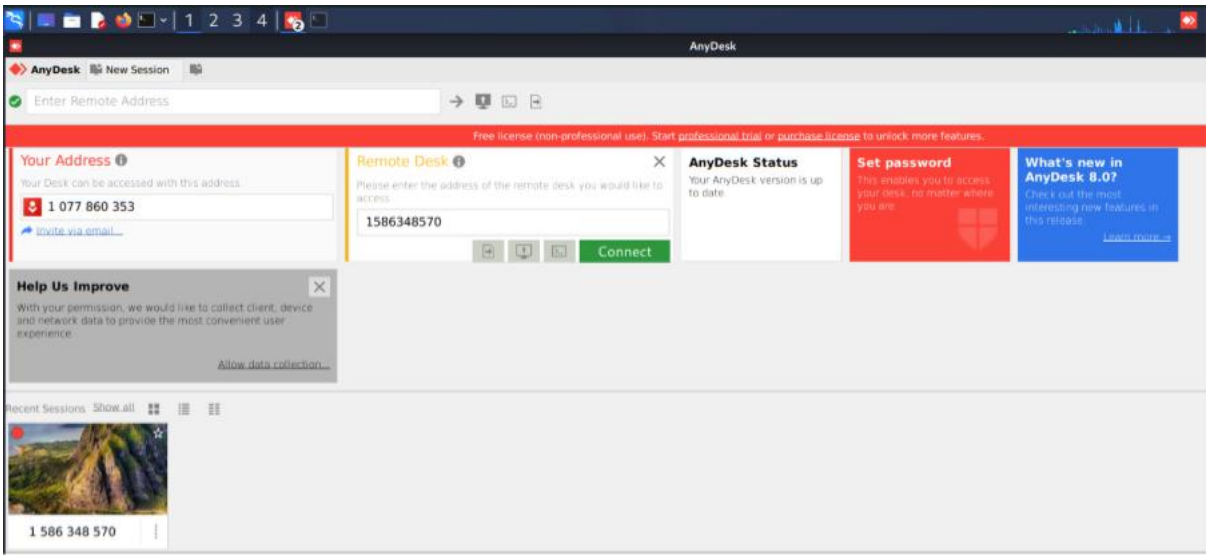
 <rule id="100501" level="10">
  <match>wazuh-edr-block.cmd</match>
  <description>EDR Active Response executed - Unauthorized Remote Access</descriptio
n>
  <group>
   active_response,
   edr,
```

```
    remote_access,
    anydesk,
  </group>
 </rule>

</group>
```

f. Thực nghiệm và kết quả

Từ máy Kali Linux, thực hiện kết nối đến Windows Endpoint thông qua AnyDesk nhằm mô phỏng hành vi sử dụng phần mềm remote access từ một địa chỉ IP không thuộc danh sách được cho phép.



Sau khi kết nối được thực hiện, kiểm tra trên Wazuh Dashboard các sự kiện được tạo bởi Rule 100500.



Table JSON

@timestamp	Sep 12, 2026 @ 11:15:07.874
_index	wazuh-alerts-4.x-2026.09.12
agent.id	001
agent.ip	192.168.56.20
agent.name	win
data.win.eventdata.destinationHostname	win
data.win.eventdata.destinationIp	192.168.56.20
data.win.eventdata.destinationIsIpv6	false
data.win.eventdata.destinationPort	7070
data.win.eventdata.image	C:\\Program Files (x86)\\AnyDesk\\AnyDesk.exe
data.win.eventdata.initiated	false
data.win.eventdata.processGuid	{dbdf5a57-d1bb-6aa4-4104-000000001c00}
data.win.eventdata.processId	8252
data.win.eventdata.protocol	tcp
data.win.eventdata.sourceIp	192.168.56.30
data.win.eventdata.sourceIsIpv6	false
data.win.eventdata.sourcePort	34924
data.win.eventdata.user	NT AUTHORITY\\SYSTEM
data.win.eventdata.utcTime	2026-09-12 04:15:05.195
data.win.system.channel	Microsoft-Windows-Sysmon/Operational
data.win.system.computer	win
data.win.system.eventID	3

id	1789186507.1651982
input.type	log
location	EventChannel
manager.name	wazuh-server
rule.description	T1219 - Unauthorized Remote Access from 192.168.56.30
rule.firedtimes	1
rule.groups	sysmon, remote_access, custom_remote_access, attack, attack.t1219, remote_access, anydesk,
rule.id	100500
rule.level	12
rule.mail	true
rule.mitre.id	T1219
rule.mitre.tactic	Command and Control
rule.mitre.technique	Remote Access Software
timestamp	Sep 12, 2026 @ 11:15:07.874

Kết quả cho thấy Wazuh phát hiện kết nối từ 192.168.56.30 thông qua AnyDesk.exe, với cổng đích 7070. Do địa chỉ IP nguồn không nằm trong danh sách IT Support, Rule 100500 được kích hoạt.

Tiếp tục kiểm tra các sự kiện được tạo bởi Rule 100501 để xác nhận Active Response đã được thực thi.



Table JSON

@timestamp	Sep 12, 2026 @ 11:15:09.932
_index	wazuh-alerts-4.x-2026.09.12
agent.id	001
agent.ip	192.168.56.20
agent.name	win
full_log	[Sat 09/12/2026 11:15:10.60] [wazuh-edr-block.cmd] Active Response launcher started
id	1789186509.1661135
input.type	log
location	active-response\active-responses.log
manager.name	wazuh-server
rule.description	EDR Active Response executed - Unauthorized Remote Access
rule.firedtimes	1
rule.groups	active_response, edr, custom, active_response, edr, remote_access, anydesk,
rule.id	100501
rule.level	10
rule.mail	false
timestamp	Sep 12, 2026 @ 11:15:09.932

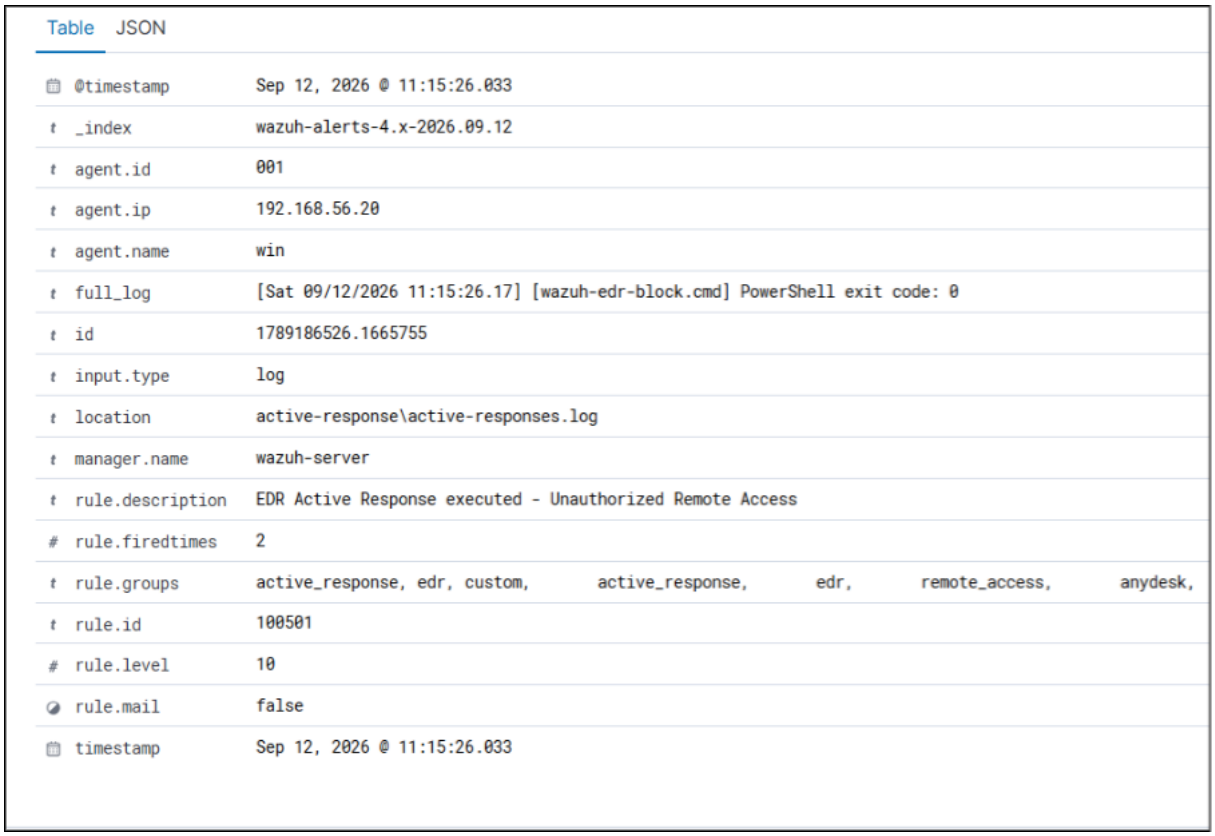
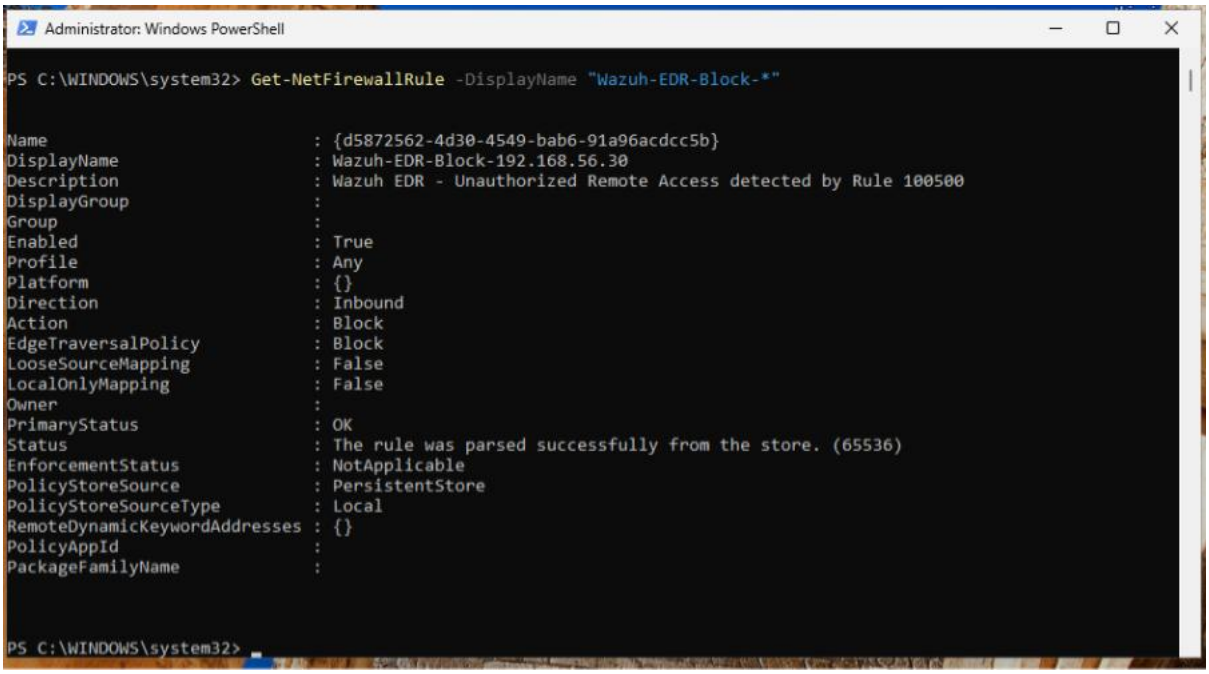


Table JSON

@timestamp	Sep 12, 2026 @ 11:15:26.033
_index	wazuh-alerts-4.x-2026.09.12
agent.id	001
agent.ip	192.168.56.20
agent.name	win
full_log	[Sat 09/12/2026 11:15:26.17] [wazuh-edr-block.cmd] PowerShell exit code: 0
id	1789186526.1665755
input.type	log
location	active-response\active-responses.log
manager.name	wazuh-server
rule.description	EDR Active Response executed - Unauthorized Remote Access
rule.firedtimes	2
rule.groups	active_response, edr, custom, active_response, edr, remote_access, anydesk,
rule.id	100501
rule.level	10
rule.mail	false
timestamp	Sep 12, 2026 @ 11:15:26.033

Kết quả cho thấy chương trình wazuh-edr-block.cmd đã được thực thi trên Windows Endpoint, xác nhận cơ chế phản hồi tự động đã được kích hoạt.

Trên Windows Endpoint, kiểm tra rule Firewall được tạo bởi Active Response.



```
Administrator: Windows PowerShell
PS C:\WINDOWS\system32> Get-NetFirewallRule -DisplayName "Wazuh-EDR-Block-*"


Name                            : {d5872562-4d30-4549-bab6-91a96acdcc5b}
DisplayName                     : Wazuh-EDR-Block-192.168.56.30
Description                     : Wazuh EDR - Unauthorized Remote Access detected by Rule 100500
DisplayGroup                    :
Group                           :
Enabled                         : True
Profile                         : Any
Platform                        : {}
Direction                       : Inbound
Action                          : Block
EdgeTraversalPolicy             : Block
LooseSourceMapping              : False
LocalOnlyMapping                : False
Owner                           :
PrimaryStatus                   : OK
Status                          : The rule was parsed successfully from the store. (65536)
EnforcementStatus               : NotApplicable
PolicyStoreSource               : PersistentStore
PolicyStoreSourceType           : Local
RemoteDynamicKeywordAddresses   : {}
PolicyAppId                     :
PackageFamilyName               :


PS C:\WINDOWS\system32>
```

Kết quả cho thấy địa chỉ IP nguồn 192.168.56.30 đã được tạo rule chặn với hướng Inbound và hành động Block, qua đó xác nhận hành vi truy cập trái phép đã được ngăn chặn.

KẾT LUẬN

Qua quá trình nghiên cứu và triển khai thực nghiệm, đề tài "Nghiên cứu giải pháp Endpoint Detection and Response (EDR) và triển khai thử nghiệm trên nền tảng mã nguồn mở Wazuh" đã cơ bản hoàn thành các mục tiêu đặt ra ban đầu, cụ thể như sau:

Về mặt lý luận, báo cáo đã hệ thống hóa được bức tranh tổng quan về bối cảnh an ninh endpoint hiện nay, chỉ ra những hạn chế cố hữu của giải pháp Antivirus truyền thống dựa trên chữ ký trước các kỹ thuật tấn công hiện đại như mã độc không dùng tệp tin, tấn công có chủ đích (APT) và hành vi lạm dụng công cụ hợp pháp. Trên cơ sở đó, đề tài đã làm rõ bản chất, nguyên lý hoạt động và vai trò chiến lược của EDR như một tuyến phòng thủ "chặng cuối" trong mô hình Phòng thủ theo chiều sâu.

Về mặt kỹ thuật, báo cáo đã phân tích chi tiết kiến trúc và cơ chế vận hành của một hệ thống EDR tiêu chuẩn, bao gồm: mô hình phân tầng Agent – Backend, chu trình xử lý khép kín sáu giai đoạn, cơ chế thu thập và chuẩn hóa dữ liệu telemetry, các tầng phân tích – phát hiện đe dọa (từ IoC, quy tắc tĩnh đến IoA và phân tích hành vi), cơ chế phản hồi – giảm thiểu sự cố theo chuẩn NIST SP 800-61r2, cũng như vai trò then chốt của khung MITRE ATT&CK trong việc chuẩn hóa và xây dựng rule phát hiện. Đề tài cũng đã chỉ ra xu hướng tích hợp AI/Machine Learning và sự tiến hóa từ EDR lên nền tảng XDR, trong đó Wazuh được xác định là giải pháp tiêu biểu đại diện cho xu hướng này.

Về mặt thực nghiệm, đề tài đã xây dựng thành công mô hình giám sát endpoint sử dụng nền tảng Wazuh trong môi trường Lab, với các thành phần Wazuh Server, Windows Endpoint và máy mô phỏng hành vi tấn công (Kali Linux). Kịch bản thực nghiệm mô phỏng hành vi truy cập từ xa trái phép thông qua AnyDesk đã chứng minh được khả năng của hệ thống trong việc:

Phát hiện chính xác sự kiện kết nối remote access từ địa chỉ IP không thuộc danh sách được phép, thông qua rule tùy chỉnh (Rule 100500) kết hợp CDB List và ánh xạ kỹ thuật T1219 theo khung MITRE ATT&CK;

Tự động kích hoạt cơ chế Active Response để thực thi hành động ngăn chặn (chặn kết nối bằng rule Firewall theo hướng Inbound) ngay khi phát hiện hành vi bất thường, qua đó xác nhận cơ chế phản hồi tự động hoạt động chính xác và kịp thời;

Ghi nhận đầy đủ bằng chứng số phục vụ điều tra thông qua Rule 100501, xác nhận Active Response đã được thực thi trên endpoint.

Kết quả thực nghiệm cho thấy Wazuh hoàn toàn có khả năng đáp ứng vai trò của một giải pháp EDR ở quy mô vừa và nhỏ, với chi phí triển khai thấp nhưng vẫn đảm bảo được các năng lực cốt lõi: giám sát liên tục, phát hiện dựa trên hành vi và tự động phản ứng trước sự cố.

Hạn chế của đề tài: Do giới hạn về thời gian và quy mô môi trường Lab, đề tài mới chỉ tập trung thực nghiệm với một số kịch bản tấn công tiêu biểu (truy cập từ xa trái phép), chưa bao quát được đầy đủ các kỹ thuật tấn công đa dạng theo ma trận MITRE ATT&CK (như leo thang đặc quyền, di chuyển ngang, khai thác lỗ hổng zero-day), cũng như chưa đánh giá được hiệu năng của hệ thống khi vận hành ở quy mô lớn với số lượng Agent và lưu lượng dữ liệu lớn.

Hướng phát triển: Trong thời gian tới, đề tài có thể được mở rộng theo các hướng sau: (1) Xây dựng thêm các kịch bản tấn công đa dạng hơn để đánh giá toàn diện khả năng phát hiện của hệ thống theo các Tactics khác nhau trong MITRE ATT&CK; (2) Nghiên cứu tích hợp các mô-đun phân tích hành vi dựa trên Machine Learning nhằm nâng cao khả năng phát hiện các mối đe dọa chưa từng biết; (3) Kết hợp Wazuh với các nguồn dữ liệu mạng và đám mây để tiến tới xây dựng một nền tảng XDR hoàn chỉnh, đáp ứng tốt hơn yêu cầu giám sát an toàn thông tin toàn diện cho tổ chức.

TÀI LIỆU THAM KHẢO

[1] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, *Computer Security Incident Handling Guide*, NIST Special Publication 800-61 Revision 2, National Institute of Standards and Technology, U.S. Department of Commerce, 2012.

[2] MITRE Corporation, *MITRE ATT&CK® Matrix for Enterprise*, [Online]. Available: https://attack.mitre.org/

[3] MITRE Corporation, *ATT&CK Technique T1219 – Remote Access Software*, [Online]. Available: https://attack.mitre.org/techniques/T1219/

[4] Wazuh Inc., *Wazuh Documentation*, [Online]. Available: https://documentation.wazuh.com/

[5] Wazuh Inc., *Wazuh Ruleset and Decoders Documentation*, [Online]. Available: https://documentation.wazuh.com/current/user-manual/ruleset/

[6] Wazuh Inc., *Active Response Documentation*, [Online]. Available: https://documentation.wazuh.com/current/user-manual/capabilities/active-response/

[7] Microsoft Corporation, *Sysmon – System Monitor, Windows Sysinternals*, [Online]. Available: https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon

[8] Sigma HQ, *Sigma – Generic Signature Format for SIEM Systems*, [Online]. Available: https://github.com/SigmaHQ/sigma

[9] Red Canary, *Atomic Red Team – Library of Adversary Emulation Tests*, [Online]. Available: https://github.com/redcanaryco/atomic-red-team

[10] Elastic N.V., *Elastic Common Schema (ECS) Reference*, [Online]. Available: https://www.elastic.co/guide/en/ecs/current/index.html

[11] Open Cybersecurity Schema Framework (OCSF) Project, *OCSF Schema Documentation*, [Online]. Available: https://schema.ocsf.io/

[12] CrowdStrike, *2024 Global Threat Report*, CrowdStrike Inc., 2024.

PHỤ LỤC